

CURSO *ONLINE* DE CIBERSEGURIDAD

Unidad 6. Análisis forense en
dispositivos móviles



Contenidos

1	INTRODUCCIÓN	4
2	SEGURIDAD EN DISPOSITIVOS MÓVILES	52
3	ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES	80
4	BUENAS PRÁCTICAS	176

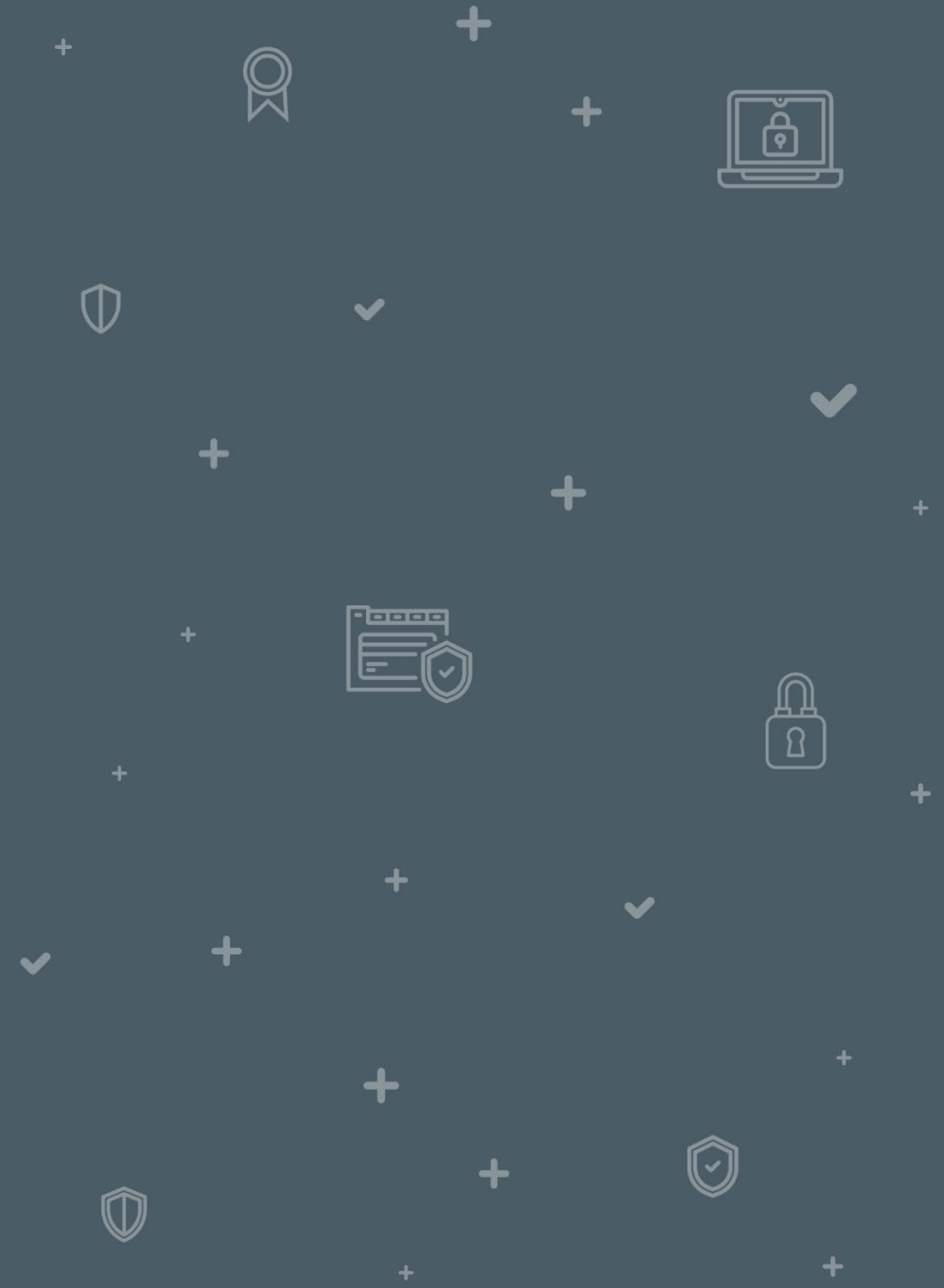
OBJETIVOS

Los principales objetivos de la unidad son:

- Conocer los elementos que componen los dispositivos móviles, así como las características esenciales de la arquitectura de los dispositivos Android e iOS.
- Analizar las diferencias existentes entre los distintos tipos de dispositivos móviles.
- Comprender las vulnerabilidades derivadas del uso de dispositivos móviles y los ataques más comunes que pueden llevarse a cabo como consecuencia.
- Analizar las principales herramientas de seguridad en dispositivos móviles y entender la función de la criptología en este ámbito.
- Conocer las fases de un análisis forense en los dispositivos móviles, así como el proceso de preservación y recolección de las evidencias, los componentes físicos de los dispositivos móviles, métodos de obtención de información, las herramientas asociadas a la investigación forense de dispositivos móviles y el proceso de análisis de aplicaciones móviles.
- Conocer las principales normativas en el ámbito de la investigación forense en dispositivos móviles.

INTRODUCCIÓN

1

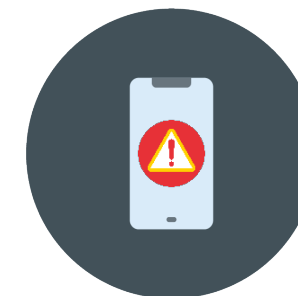


1 INTRODUCCIÓN

Contexto

Los dispositivos móviles han sufrido una gran evolución desde su origen hasta la actualidad, en la que se han convertido en elementos indispensables para nuestro día a día.

Debido a la gran expansión del uso de esta clase de dispositivos en materia de comunicación, relaciones interpersonales, negocios, hábitos sociales, etc., también es cada vez mayor el número de ataques e incidentes que tienen como objetivo estos dispositivos debido al gran volumen de información que almacenan, por lo que es indispensable poder analizarlos en busca de evidencias ante una posible incidencia dentro del ámbito de la investigación forense.



1 INTRODUCCIÓN

Contexto

Antiguamente, no existían muchas maneras de realizar un análisis forense en profundidad más allá de métodos manuales para la extracción de información. Sin embargo, se han ido desarrollando diferentes tipos de aplicaciones y técnicas para realizar un análisis forense óptimo de estos dispositivos.



1 INTRODUCCIÓN

Contexto

Los teléfonos móviles almacenan grandes cantidades de información que pueden resultar relevantes para la resolución de una incidencia, un ataque o una investigación. Algunos de los datos que este tipo de dispositivos pueden revelar durante una investigación forense son los siguientes:

- El historial de llamadas y la lista de contactos.
- Cualquier tipo de información compartida en las aplicaciones de mensajería instantánea.
- Datos de diferentes formatos multimedia, como vídeos, imágenes y mensajes de voz.
- Contraseñas.
- Información de las aplicaciones instaladas.
- Ficheros del sistema, *logs* y mensajes de error.
- Archivos borrados.
- Geolocalización del dispositivo.

1 INTRODUCCIÓN

Contexto

Dos de las cuestiones que más se estudian en un análisis forense en móviles son:

- **El almacenamiento:** la información no volátil contenida en la memoria interna y/o en la memoria extraíble si el dispositivo dispusiera de esta última.
- **Las comunicaciones mantenidas con el móvil:** se pueden llevar a cabo de diferentes maneras, ya sea a través de llamadas, videollamadas, mensajes, vídeos, ubicación en tiempo real, etc.



1 INTRODUCCIÓN

Componentes físicos de un dispositivo móvil a analizar

Para poder realizar una investigación forense de forma correcta también es importante saber de qué componentes físicos consta un dispositivo móvil, ya que pueden ser relevantes en función del caso a analizar:

- **La antena:** su objetivo es enviar y recibir las señales electromagnéticas que utiliza el dispositivo para establecer la comunicación.
- **Los filtros de radiofrecuencia:** se utilizan en los dispositivos móviles para llevar a cabo todas las conversiones de frecuencia de las señales.
- **Los convertidores de señal analógica a digital y viceversa:** realizan los tipos de conversiones cuando es necesario.
- **El procesador de señales de voz:** es el componente encargado de procesar las señales de voz para poder establecer conversaciones telefónicas.
- **El procesador:** los dispositivos móviles cuentan con un procesador para poder realizar todas sus funciones.

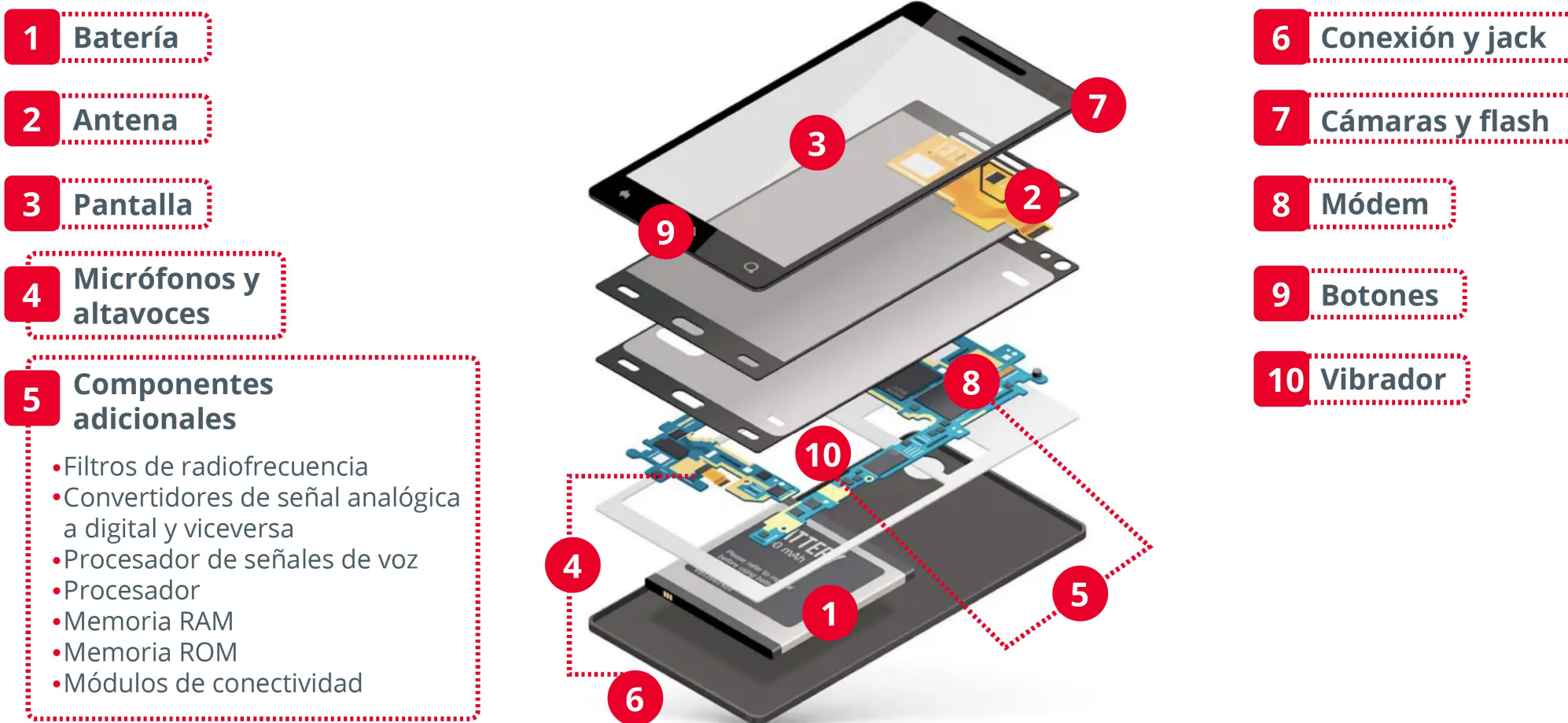
1 INTRODUCCIÓN

Componentes físicos de un dispositivo móvil a analizar

- **La memoria RAM:** hace referencia a la memoria volátil del dispositivo.
- **La memoria ROM:** se utiliza como el almacén interno del teléfono.
- **La pantalla:** sus componentes pueden variar en función de la tecnología que utilice (LED, AMOLED, OLED, etc.).
- **Los módulos de cámara:** hacen referencia a todos los componentes relacionados con la cámara fotográfica de un dispositivo móvil.
- **El micrófono:** este componente convierte las señales acústicas del exterior en señales que puedan ser interpretadas por el procesador.
- **El altavoz:** de manera similar al anterior, este convierte las señales de audio del dispositivo en sonido.
- **Los módulos de conectividad:** hacen referencia a todos los componentes relacionados con la conectividad de un dispositivo móvil, como la red wifi, la conexión *bluetooth*, la localización GPS y la memoria externa o USB.

1 INTRODUCCIÓN

Componentes físicos de un dispositivo móvil a analizar

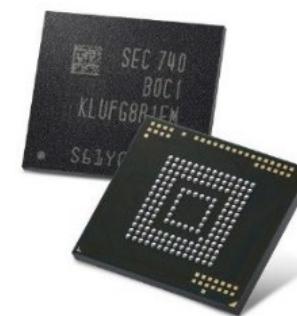


1 INTRODUCCIÓN

Componentes de un dispositivo móvil

La metodología para realizar un análisis forense es similar en todos los dispositivos móviles. Como vimos en la unidad anterior, el investigador deberá responder a cuestiones como qué, cuándo, dónde, cómo y/o por qué ha ocurrido un hecho y, para ello, deberá analizar los diferentes componentes de un dispositivo, como:

- **La memoria interna:** es la memoria incluida en el propio teléfono, por lo que es toda la capacidad de almacenamiento que tiene el sistema operativo del móvil y donde se instalan todas las aplicaciones del teléfono.

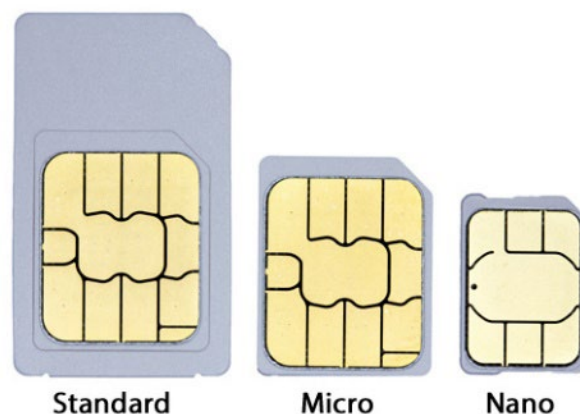


Fuente: *Ejemplo memoria interna*
[Ilustrativo] Extraído de
<https://www.xataka.com>

1 INTRODUCCIÓN

Componentes de un dispositivo móvil

- **La tarjeta SIM** (del inglés, *Subscriber Identity Module* o módulo de identificación de abonado) es un chip integrado en una tarjeta de plástico que se encarga de guardar, de manera segura, la clave de servicio del usuario o código PIN para identificarse en la red móvil de un operador telefónico, lo que permite que las redes de los operadores puedan identificar a todos sus usuarios y habilita a cada usuario para que pueda acceder tanto a su número de teléfono como a los servicios que ofrece el operador.



Fuente: *Ejemplo tarjetas SIM* [Ilustrativo]
Extraído de <https://www.simoptions.com>

1 INTRODUCCIÓN

Componentes de un dispositivo móvil

- **La memoria externa:** hace referencia a los dispositivos de almacenamiento que no forman parte intrínsecamente del dispositivo móvil, sino que se integran en él para asumir una mayor capacidad de almacenamiento. La memoria externa más conocida es la **tarjeta micro SD** (del inglés, *Secure Digital*), un tipo de memoria extraíble que se utiliza para ampliar el almacenamiento de la memoria interna. Las tarjetas SD se utilizan para almacenar información digital, ya sean programas o archivos. Al principio tenían una capacidad de 32 o 64 MB (megaByte), pero ahora podemos encontrar tarjetas de hasta 1 TB (teraByte).



Fuente: *Ejemplo de tarjeta MicroSD*
[Ilustrativo] Extraído de
<https://es.webuy.com>



Fuente: *Ejemplo de tarjeta SD*
[Ilustrativo] Extraído de
<https://www.elespanol.com/>

1 INTRODUCCIÓN

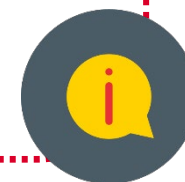
Inconvenientes en el análisis forense de dispositivos móviles

Algunos inconvenientes que pueden surgir a la hora de realizar un análisis forense en los dispositivos móviles son:

- Los mecanismos de seguridad, como el código PIN, la contraseña, el patrón o acceso de doble autenticación que se utilizan para desbloquear los terminales, que pueden dificultar el acceso por parte del investigador al contenido del móvil si no los conoce.
- En la actualidad, gran parte de la información que generan los dispositivos móviles se almacena en la nube, la cual puede tener diferentes tipos de arquitectura y, adicionalmente, diferentes proveedores de dicho servicio, lo que puede alargar la investigación y hacerla más compleja debido a la dificultad de acceso a los datos.

¿Sabías qué?

En marzo de 2023, casi el 71 % de dispositivos eran Android, mientras que el 28 % restante eran iOS. [\[1\]](#)



1 INTRODUCCIÓN

Inconvenientes en el análisis forense de dispositivos móviles

- La necesidad de mantener intacta toda la información contenida en el dispositivo móvil, ya que cualquier alteración puede hacer inservibles las evidencias.
- Por norma general, la extracción de datos de un dispositivo móvil suele ser más complicada que en un ordenador.
- Los ciberdelincuentes llevan a cabo una gran variedad de técnicas cuando realizan un ataque para impedir que los investigadores sean capaces de encontrar evidencias, lo que dificulta conocer todos los factores implicados en el ataque para prevenir el riesgo de que se pueda volver a producir en un futuro.

1 INTRODUCCIÓN

Dispositivos Android

Como hemos visto en unidades anteriores, el sistema operativo es el punto intermedio, la interfaz, entre los recursos del sistema –dispositivo móvil-, como la CPU y la memoria, y las aplicaciones que necesitan emplear estos recursos. En el ámbito de los dispositivos móviles existen dos sistemas operativos que son los más habituales, Android e iOS. En este apartado vamos a explicar su arquitectura y las diferencias entre ellos:

- **Android:** este sistema operativo ha sido desarrollado por un consorcio de desarrolladores conocido como el Open Handset Alliance. Se trata de un sistema operativo para dispositivos móviles basado en una versión del Kernel de Linux. Una de las principales características de este sistema operativo es que el código fuente es *open source*, es decir, se publica para que los usuarios puedan desarrollar sus propios proyectos con Android, lo cual es una ventaja. Sin embargo, a su vez, puede exponer las vulnerabilidades del sistema operativo.



android

Fuente: *Logo Android* [Logo]
Extraído de
<https://es.logodownload.org>

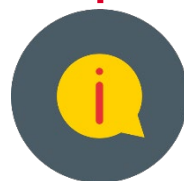
1 INTRODUCCIÓN

Dispositivos iOS

- **iOS:** es un sistema operativo creado y desarrollado por Apple de manera exclusiva para sus dispositivos táctiles. Es el segundo sistema operativo para móviles más utilizado en el mundo después de Android. A diferencia de este, iOS no es *software* libre, aunque sí es cierto que algunas partes sí lo son, como su núcleo, el lenguaje de programación Swift y las herramientas para poder desarrollar aplicaciones. Por otro lado, el ecosistema de Apple es mucho más cerrado que el de Android, por lo que solo se encontrará instalado iOS en dispositivos de Apple, como el iPhone o el iPad, no existiendo la posibilidad de instalarlo en dispositivos de terceros. La versión de iOS se renueva anualmente y también se van lanzando algunos tipos de actualizaciones intermedias que permiten añadir algunas mejoras menores o la corrección de errores de seguridad, entre otras.

¿Sabías qué?

Cuando Apple salió a bolsa en 1980 sus acciones valían únicamente 22 dólares.



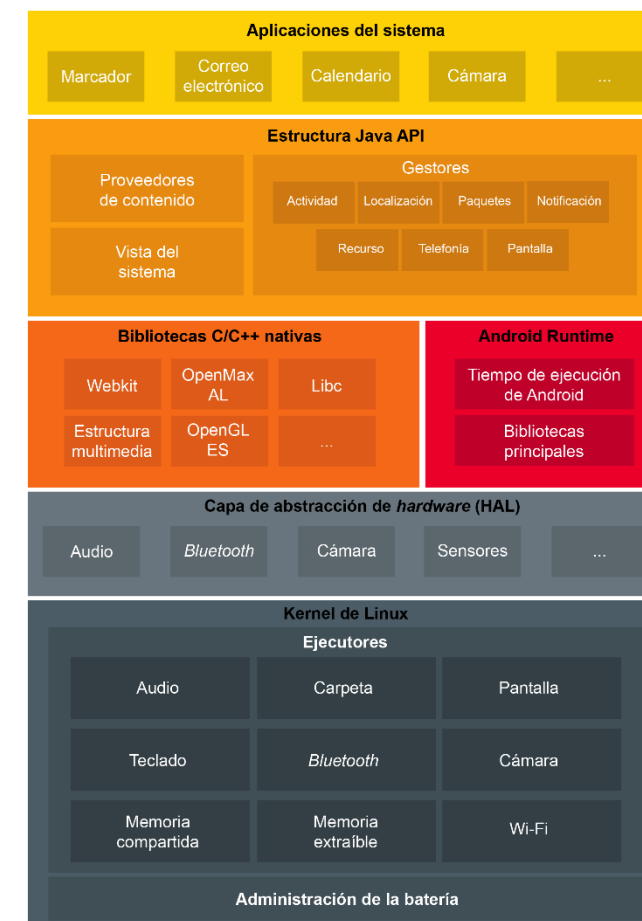
Fuente: Logo iOS [Logo]
Extraído de <https://iconos8.es>

1 INTRODUCCIÓN

Arquitectura Android

Entre los componentes de la arquitectura de Android destacan:

- **Kernel:** es el componente principal del sistema operativo y se encarga de realizar las funcionalidades implícitas del dispositivo como la administración de la memoria.
- **Capa de abstracción de *hardware* o HAL** (del inglés *Hardware Abstraction Layer*): es un elemento encargado de realizar la función de interfaz entre el *software* y el *hardware* del dispositivo. El HAL permite que el *software* funcione de forma independiente al *hardware* que tenga el dispositivo, es decir, si, por ejemplo, una aplicación necesita utilizar la cámara del dispositivo, esta capa daría acceso a la aplicación al componente de la cámara.



1 INTRODUCCIÓN

Arquitectura Android

- **Tiempo de ejecución de Android o ART** (del inglés, *Android Runtime*): es la máquina virtual utilizada por el sistema operativo para que se ejecuten las aplicaciones (apps). Se caracteriza por utilizar la tecnología AOT o *Ahead Of Time*, cuya función es que cada vez que se instala una aplicación en el móvil crea un archivo especial –archivo compilado– para que la app pueda ser utilizada rápidamente cada vez que se desee. Hasta la versión 4.4 de Android se utilizó la máquina Dalvik con otra tecnología diferente, conocida como JIT o *Just In Time*, que funcionaba de forma diferente y hacía que fuese más lento y consumiese más batería iniciar una aplicación, aunque, a cambio, ocupaba menos espacio en memoria.

1 INTRODUCCIÓN

Arquitectura Android

- **Bibliotecas C/C++ nativas:** esta capa se encarga de proporcionar componentes esenciales para el funcionamiento de partes fundamentales del SO, como el ART y el HAL que acabamos de ver, los cuales requieren de estas bibliotecas para poder funcionar. Una biblioteca es un conjunto de archivos que se utiliza para desarrollar *software*, facilitando así la programación.



1 INTRODUCCIÓN

Arquitectura Android

- **Marco de trabajo de la API de Java:** en esta capa se pueden encontrar todas las bibliotecas Java que requieren las aplicaciones de Android. También es el lugar donde se alojan todas las características necesarias para el desarrollo de aplicaciones para dispositivos Android. Una API (del inglés, *Application Programming Interface* o interfaz de programación de aplicaciones) es un conjunto de funciones y protocolos que se utiliza para el desarrollo e integración del *software* de las aplicaciones, ya que se encarga de permitir que dos aplicaciones de *software* se comuniquen entre sí, es decir, es la forma en la que una aplicación expone datos y funcionalidades hacia otras aplicaciones.
- **Capa de aplicaciones:** se encarga de la ejecución, comunicación y estabilidad de las aplicaciones (apps) instaladas en el equipo, tanto aquellas que vienen por defecto con el sistema operativo como aquellas que se instalan posteriormente en el dispositivo.

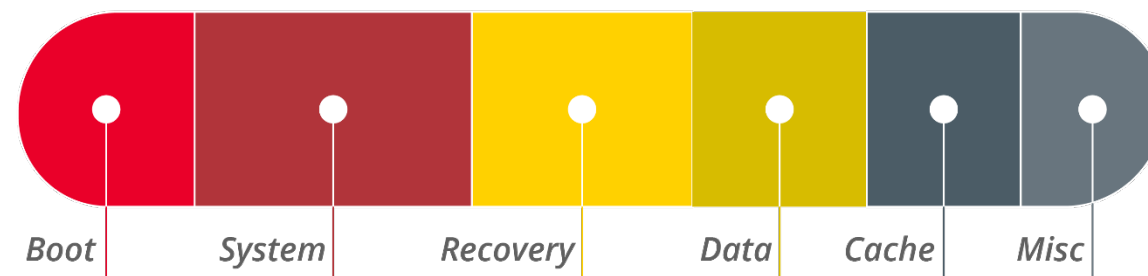
1 INTRODUCCIÓN

Arquitectura Android

En un análisis forense no solo es importante conocer los componentes del sistema operativo, sino también cómo se almacena la información en memoria. En el caso de Android, la memoria se divide en diferentes partes, a cada una de ellas se la conoce como partición y tiene diferentes funciones en el dispositivo. En los sistemas Android existen seis particiones principales que se encuentran dentro del directorio raíz del sistema:

- **Boot:** la partición de *boot* del dispositivo es la encargada de permitir que el dispositivo se encienda. Esta partición contiene el Kernel que proporciona la información necesaria para que se realicen las funciones del resto de componentes de SO, del dispositivo y del disco de memoria RAM.

Detalles de la partición en Android



Fuente: *Esquema de las seis principales particiones Android* [Gráfico] Adaptado de <https://www.cnblogs.com>

1 INTRODUCCIÓN

Arquitectura Android

- **System:** en esta partición se almacena todo el contenido del sistema operativo del dispositivo, a excepción del Kernel y el disco de memoria RAM. Por otro lado, también contiene todas las aplicaciones que vienen preinstaladas, así como la interfaz gráfica del dispositivo.
- **Recovery:** proporciona un sistema de recuperación del equipo, dando una alternativa para encender el dispositivo, es decir, la función de esta partición está basada en realizar copias de seguridad.
- **Data:** en esta partición se almacena todo el contenido multimedia que haya generado el usuario, como la lista de contactos, mensajes, aplicaciones instaladas, etc.
- **Caché:** se encarga de guardar toda la información de caché del dispositivo. La caché es un tipo de memoria temporal que se guarda entre la CPU y la memoria RAM y su función consiste en acelerar el proceso de ejecución de las solicitudes que se hagan en el sistema.
- **Misc:** en esta partición se almacenan los diferentes datos relacionados con la configuración del dispositivo.

1 INTRODUCCIÓN

Arquitectura Android

Ahora que entendemos cómo se encuentran organizadas las particiones del sistema en los dispositivos Android, vamos a conocer en qué consiste la jerarquía de ficheros. Los ficheros suelen estar organizados de manera similar, pero existen diferencias dependiendo del fabricante y de la versión de Android que tenga el dispositivo. Dependiendo del dispositivo Android que se analice, la ubicación de los directorios puede cambiar. Principalmente, podremos encontrar directorios en la carpeta raíz o *root* de Android, una carpeta desde la que se configura todo el sistema Android y, dentro de este directorio raíz, se pueden encontrar estos directorios en diferentes particiones.

Algunos de los directorios más importantes de los dispositivos Android son:

- **Acct:** en este directorio se almacena la información de las cuentas del usuario. Este directorio se ubica en mismo directorio raíz del sistema.

1 INTRODUCCIÓN

Arquitectura Android

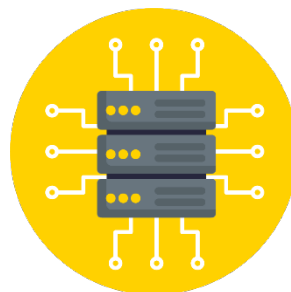
- **Caché:** contiene todos los datos de la caché del dispositivo. Este directorio se encuentra dentro de la partición de caché.
- **D:** la función de este fichero consiste en depurar o limpiar el Kernel. Posee una conexión a la ruta `/sys/kernel/debug`. Este directorio se encuentra en el directorio raíz del sistema.



1 INTRODUCCIÓN

Arquitectura Android

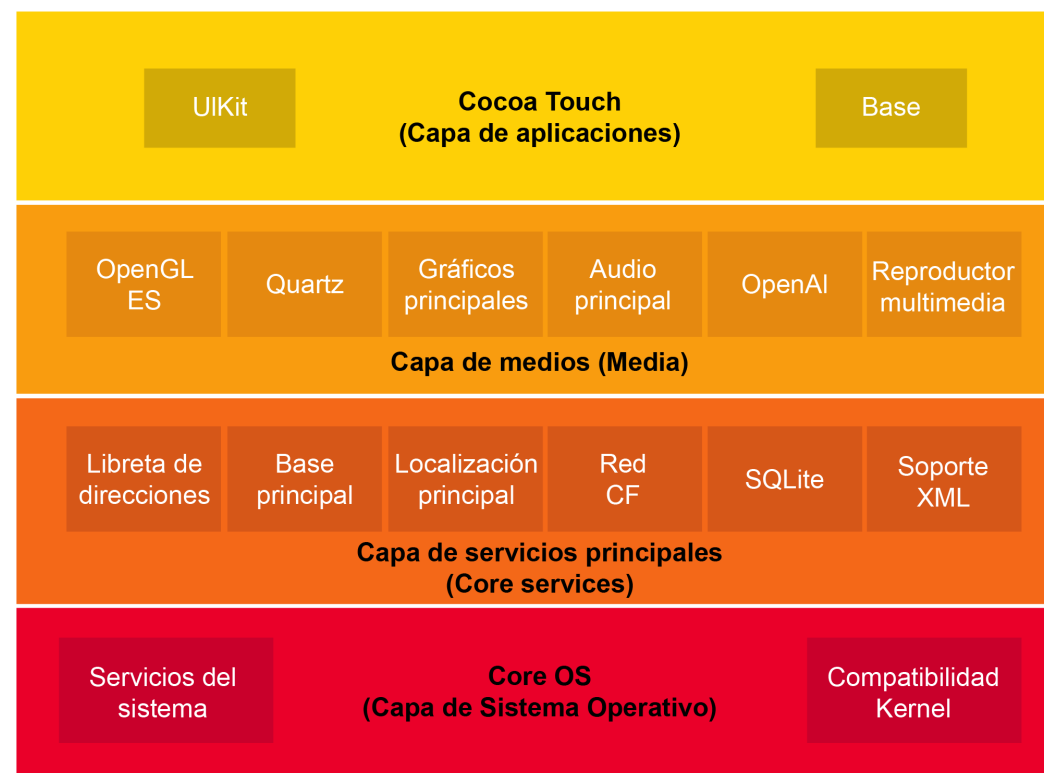
- **Data:** es el almacén de todos los datos que el usuario ha guardado en el dispositivo, tanto de forma manual como relativos a las aplicaciones que utilice. Este directorio se ubica dentro de la partición de *system*.
- **Dev:** se encarga de almacenar los *drivers* del dispositivo. Los *drivers* son programas informáticos que se desarrollan para que el sistema operativo pueda interactuar con diferentes componentes periféricos y accesorios, como la pantalla, los auriculares inalámbricos, el reloj inteligente, el procesador, la impresora, etc. Este directorio se encuentra dentro del mismo directorio raíz del sistema.
- **Init:** en este fichero se almacena el programa de inicio de Android, denominado de igual manera que la carpeta que lo contiene. Este directorio se ubica dentro del mismo directorio raíz del sistema.



1 INTRODUCCIÓN

Arquitectura iOS

Por otro lado, el sistema operativo iOS se basa en el sistema Unix y cuenta con cuatro capas principales en su arquitectura:



Fuente: *Arquitectura iOS* [Gráfico]
Adaptado de <https://www.researchgate.net>

1 INTRODUCCIÓN

Arquitectura iOS

- **Cocoa Touch o capa de Aplicaciones:** también conocida como la capa de aplicación de los sistemas iOS. Su función consiste en servir como interfaz al usuario para que este pueda trabajar con el sistema operativo de iOS.
- **Media o capa de medios:** esta capa proporciona las capacidades de audio, vídeo, animaciones y gráficos a las aplicaciones que se encuentren instaladas en el dispositivo.
- **Core services o capa de servicios principales:** se encarga de dar acceso a los servicios fundamentales del sistema operativo. Entre estos servicios se encuentran las bibliotecas de SQLite (para bases de datos), las bibliotecas de XML (para almacenar datos legibles), etc.
- **Core OS o capa del Sistema Operativo:** al igual que en el sistema Android, esta capa hace referencia al ámbito del Kernel, es decir, a los servicios básicos del sistema operativo, como administrar la memoria virtual, el sistema de archivos, etc.

1 INTRODUCCIÓN

Arquitectura iOS

Por otro lado, también es importante conocer cómo se estructura la arquitectura de estos dispositivos iOS. Los dispositivos iOS poseen una estructura de disco dividida en directorios, en estos se almacenan todas las carpetas y archivos del dispositivo. Por ejemplo, mientras que en un equipo Windows el directorio raíz de un disco se representa con una letra y dos puntos (C:), y desde este podemos encontrar todos los archivos de un disco, en los dispositivos iOS el directorio raíz se representa con una barra (/).

Los directorios más importantes de los dispositivos iOS son:

- **Root:** es el directorio principal del usuario *root*, es decir, el usuario que tiene todos los privilegios en el dispositivo. Contiene los directorios de bibliotecas y el soporte de aplicaciones por defecto. Al igual que en Android, el directorio raíz es el directorio desde el que se monta todo el sistema de iOS.

1 INTRODUCCIÓN

Arquitectura iOS

- **Directorio de aplicaciones preinstaladas:** en él se almacenan las aplicaciones que vienen por defecto en un dispositivo de iOS. Este directorio se almacena dentro del directorio de var.
- **Directorio de aplicaciones de la tienda:** en este directorio se almacenan las aplicaciones que se descarguen de la tienda de iOS o App Store. Este directorio se almacena dentro del directorio de var.
- **Directorio de datos:** es decir, los datos locales de las aplicaciones que haya instaladas en el dispositivo se almacenan en este directorio. Este directorio se almacena dentro del directorio var.
- **Directorio de datos compartidos:** en él se almacenan los datos que comportan un grupo de aplicaciones. Este directorio se almacena dentro del directorio *private*.

1 INTRODUCCIÓN

Arquitectura iOS

- **iOS *keychain***: hace referencia a toda la información de contraseñas que se guardan en las aplicaciones, como la contraseña de la red inalámbrica wifi, aplicaciones de música, redes sociales, etc. Este directorio se almacena dentro del directorio *private*.



1 INTRODUCCIÓN

Diferencias entre dispositivos móviles

Existen diferencias entre los diferentes dispositivos móviles que se encuentran en el mercado:

- **Móviles que poseen UICC** (del inglés, *Universal Integrated Circuit Card*): este tipo de dispositivos se caracterizan porque no poseen una tarjeta SIM extraíble, sino una tarjeta denominada UICC. Se trata de una tarjeta integrada que hace la función de la tarjeta SIM. Los teléfonos que poseen la tarjeta UICC difieren de los que utilizan tarjeta SIM en que esta no almacena información específica del cliente, como pueden ser contactos, directorio telefónico u otros datos personales.



1 INTRODUCCIÓN

Diferencias entre dispositivos móviles

- **Dispositivos iOS:** todos los dispositivos Apple cuentan con chips criptográficos, denominados *data protection*. Los ficheros que poseen estos chips están protegidos con una clave que se utiliza para cifrado el fichero (cifrado simétrico). Esta clave es almacenada como un metadato del propio fichero. Existen diferentes clases de *data protection*:
 - **Clase A:** protección completa.
 - **Clase B:** protegido, a menos que se abra.
 - **Clase C:** protegido hasta la primera autenticación del usuario. Esta es la que solemos encontrar por defecto.
 - **Clase D:** sin protección.

1 INTRODUCCIÓN

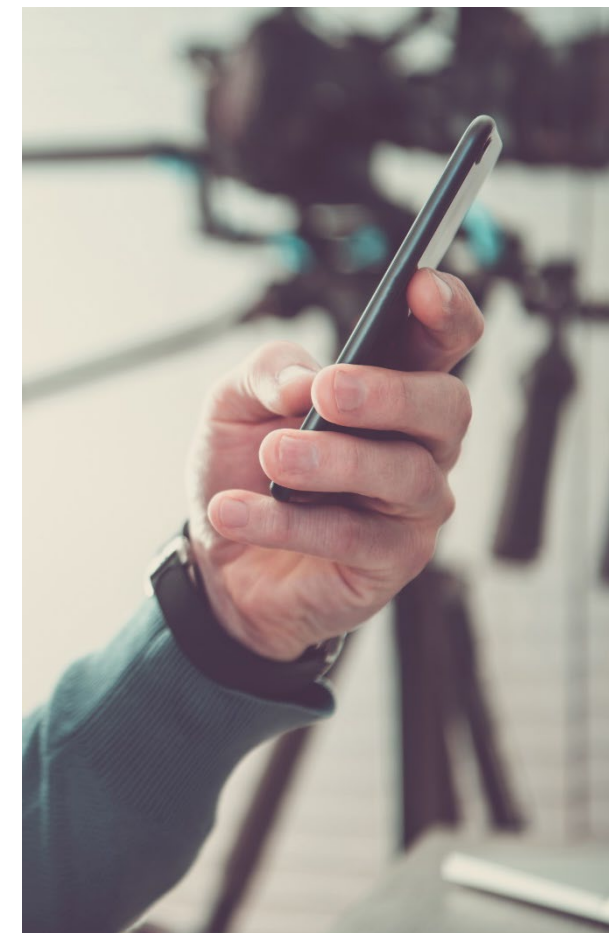
Diferencias entre dispositivos móviles

Cuando la función de *data protection* está activada, si eliminamos un archivo también se eliminará la clave del archivo, dado que cada archivo posee una clave única generada por *data protection*, lo cual hace que recuperarlo sea prácticamente imposible y dificulte la realización de un examen forense. Por ello, para evitar que los datos de una evidencia sean borrados de forma remota utilizando las funcionalidades que nos otorga iCloud[.]com, ya que se podrían utilizar para borrar archivos de manera remota, se deberá aislar el dispositivo de Apple desde el primer momento en el que adquiera el dispositivo móvil. Si los archivos del sistema se encuentran encriptados por el *data protection*, el analista forense deberá recuperar las claves de encriptación almacenadas en el repositorio de claves del dispositivo. Por otro lado, Apple también proporciona la encriptación de los datos almacenados en una copia de seguridad.

1 INTRODUCCIÓN

Diferencias entre sistemas operativos

- **Dispositivos Android:** en este sistema operativo la gran mayoría de los datos, tanto de aplicaciones como del usuario, pueden ser encontrados dentro de tablas de SQLite que están guardadas en archivos separados por cada una de las aplicaciones instaladas. Habrá que tener en cuenta que la gran mayoría de las herramientas de investigación forense soportan hasta el 5 % de las aplicaciones que hay en la tienda de aplicaciones de Android o Play Store, dado que no se puede dar soporte a todas las aplicaciones nuevas, lo que haría necesario realizar un volcado de memoria o *dump* de todas las tablas SQLite y una búsqueda por términos de los datos relevantes que se quieran obtener. Como ya hemos mencionado anteriormente, en la partición *data* se almacenará la información sobre las aplicaciones instaladas en el dispositivo Android.



1 INTRODUCCIÓN

Diferencias entre sistemas operativos

Otra diferencia que se debería tener en cuenta a la hora de hacer un análisis forense son las diferencias en cómo se encuentran estructurados los diferentes ficheros entre los diferentes tipos dispositivos, tanto en Android como en iOS, como ya se ha explicado anteriormente en el documento. Esto es útil para un investigador forense, dado que conocer cómo y dónde se almacenan los datos en los diferentes sistemas operativos puede servir para priorizar las ubicaciones que más posibilidades tienen de darle evidencias dependiendo del caso que está tratando.



1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM

La tarjeta SIM es utilizada por los dispositivos móviles para autenticar la suscripción a la red del proveedor de manera segura y puede contener una gran cantidad de datos relevantes para el análisis forense. Gran parte de la información que contiene la tarjeta SIM es modificable, por lo que es importante que, a la hora de tratarla, se utilice un bloqueador de escritura para evitar que se produzca alguna modificación de los datos o se contaminen las evidencias y, como consecuencia, se pueda romper la cadena de custodia.

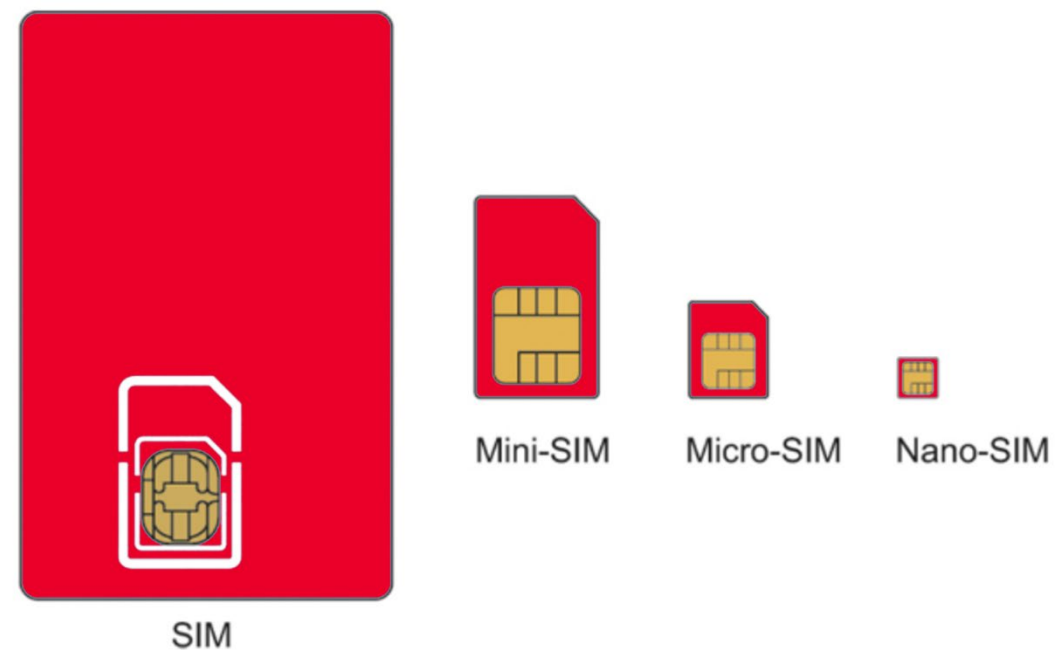
Entre las características de la tarjeta SIM podemos encontrar:

- Comprende entre 16 y 64KB de memoria interna.
- Contiene un procesador y un sistema operativo.
- Se utiliza para detectar al suscriptor de la compañía telefónica a través del número de teléfono o mediante un algoritmo de identificación del suscriptor dentro de la red.

1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM

Existen diferentes tipos de tarjeta SIM, como la mini SIM, la micro SIM y la nano SIM:



Fuente: *Tipos de tarjetas SIM* [Ilustrativo] Extraído de <https://www.muycomputer.com>

1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM

Para poder acceder a la información contenida dentro de la tarjeta SIM se requerirá el desbloqueo de la tarjeta mediante código PIN. En algunos casos, el acceso mediante clave PIN puede estar desactivado por diferentes motivos, en cuyo caso será necesario introducir el código PUK para poder acceder a la tarjeta SIM bloqueada.

La información que podemos extraer de la tarjeta SIM puede ser:

- La preferencia de idioma.
- La localización del dispositivo.
- El listado de llamadas.
- Los SMS enviados y recibidos.
- El nombre del proveedor.
- La red móvil contratada.
- Los últimos números que se han marcado.
- El listado de contactos.
- La clave usada para cifrar la última llamada.
- ICCID o *Integrated Circuit Card Identity*: es el número de serie de hasta 19 dígitos que el fabricante asigna al chip de la tarjeta SIM.
- La clave de autenticación (KI): es un valor de 16 bytes para autenticar la tarjeta SIM en la red móvil.

1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM

- IMSI o *Internacional Mobile Subscriber Identity*.
- La clave de identificación de área local (LAI): hace referencia a las redes de los operadores que están divididas en áreas locales y cada una de ellas tiene un número LAI único, por lo que cuando un dispositivo móvil cambia de área local, la nueva LAI se guarda en la tarjeta SIM.

Las tarjetas SIM pueden almacenar tres tipos diferentes de datos relacionados con los suscriptores:

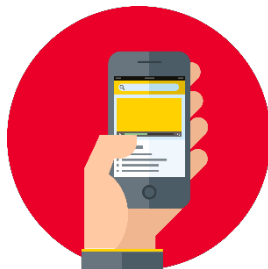
- **Datos fijados:** son aquellos que se almacenan previamente a la venta de la suscripción, como el IMSI, la clave de autenticación o el ICCID.
- **Datos de red temporal:** son aquellos que se generan con el uso de red, como el LAI.
- **Datos de servicio:** son aquellos que se generan con el uso del dispositivo, como la preferencia del lenguaje.

1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM: artefactos

Algunos de los artefactos más importantes que se encuentran almacenados dentro de la tarjeta SIM son:

- **El último número marcado (LND):** el LND es una lista de la tarjeta SIM que almacena las últimas llamadas realizadas por el dispositivo. Este listado solo contendrá las llamadas realizadas desde el dispositivo, no las llamadas recibidas ni las llamadas perdidas que el usuario haya hecho.
- **Location information:** el proveedor de la línea telefónica necesita constantemente saber la localización de la tarjeta SIM para saber en qué lugar se encuentra para dar el servicio, lo cual puede ser útil en una investigación forense con el fin de saber cuáles han sido las ubicaciones en las que se ha encontrado el dispositivo móvil que se está analizando. Esta información se encontrará dentro del fichero EFloci.



1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM: artefactos

- **La agenda telefónica:** esta agenda será almacenada dentro del fichero Dfphonebook.
- **El listado de mensajes SMS:** aunque la utilización de los mensajes SMS ha decaído en los últimos años, aún sigue siendo relevante, ya que pueden contener información importante para la investigación y permiten identificar y leer los mensajes que han sido recibidos, leídos, enviados, en espera de ser enviados o borrados. El listado de los SMS se ubica en el fichero Efsms.



1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM: ICCID

Respecto del ICCID o *Integrated Circuit Card Identity* podemos encontrar las siguientes características:

- **La dirección del expedidor (IIN):** (7) país, operador y red. Se desglosa en:
 - Identificador de actividad industrial (MII): (2) Industria (telecomunicaciones: 89).
 - Código de país: (1-3). País (España +34).
 - Identificador del emisor (1-4). Expedidor (España: 2 dígitos).
- **Número de identificación de cuenta individual.**
- **Cifra de control de Luhn (1). Checksum control de errores:** hace referencia a una suma de verificación. Tiene como objetivo detectar posibles cambios accidentales en una secuencia de datos y así proteger su integridad, verificando que no hay discrepancia entre la suma inicial y otra final.

1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM: IMSI

Respecto del IMSI, es un código único de identificación que sirve para identificarse en redes GSM y UMTS. Una red GSM (del inglés, *Global System for Mobile Communications*) es un tipo de red utilizado para la transmisión móvil de voz y datos, conocida como 2G, mientras que una red UMTS (del inglés, *Universal Mobile Telecommunications System*) es su sucesora, conocida como red 3G.

Cuando el teléfono se enciende, se envía su IMSI al operador de la red solicitando acceso y autenticación. Así, el operador de la red busca en su base de datos el IMSI y la clave de autenticación (KI) relacionada y genera un número aleatorio (RAND) y lo firma con la KI de la SIM, creando así un número conocido como SRES_1 (*signed response 1* o respuesta firmada 1). El móvil cliente de la red envía el RAND a la tarjeta SIM, que también lo firma con su KI, y envía el resultado (SRES_2) de vuelta al operador de la red. Finalmente, el operador de la red compara su SRES_1 con el SRES_2 generado por la tarjeta SIM. Si los números coinciden, la SIM es autenticada y se le concede acceso a la Red.

1 INTRODUCCIÓN

Obtención de datos de la tarjeta SIM: IMSI

El IMSI esta formado por hasta 15 dígitos:

- **El código del país (MCC):** (3) país (España: 214).
- **Código de operador de red (MNC):** (2-3): se trata del operador de red.
- **Código de estación móvil (MSIN):** (9-10): es un identificador del operador para cada línea de sus clientes.



1 INTRODUCCIÓN

Redes móviles

Según han avanzado la tecnología y las comunicaciones, se han comenzado a utilizar diferentes tecnologías en las redes móviles. Algunas destacadas son:

- **Global System for Mobile communications (GSM) o Sistema Global para comunicaciones móviles:** es la red más popular. Funciona a través de tecnología de segunda generación (2G), aunque cuenta con una extensión 3G conocida como UMTS.
- **Code Division Multiple Access (CDMA) o código de división de acceso múltiple:** es una de las redes móviles que, aunque en Europa no se utiliza, América o Asia sí la utilizan, como es el caso de EE.UU., Canadá o India. Los dispositivos móviles con red CDMA no utilizan tarjetas SIM, sino que están vinculados a un operador telefónico y a su red. El inconveniente es que si se cambia de operador, también se debe cambiar de dispositivo o liberarlo del proveedor actual.

1 INTRODUCCIÓN

Redes móviles

- **General Packet Radio Service (GPRS) o servicio general de radio por paquetes:** este servicio ha introducido el uso de paquetes para mejorar la transmisión de datos móviles en las redes 2G. Se trata de una combinación entre 2G y 3G, por lo que a veces se le conoce como red 2.5G.
- **Enhanced Data Rates for GSM Evolution (EDGE) o datos mejorados para la evolución del GSM:** este sistema mejoraba las tasas de transmisión de datos en las redes móviles, ya que surgió de la necesidad de poder transmitir información entre diferentes dispositivos, independientemente del espacio físico o la distancia que existiera entre ellos. Actúa como puente entre las redes 2G y 3G y se considera una evolución de GPRS.
- **Universal Mobile Telecommunications System (UMTS) o sistema universal de telecomunicaciones móviles:** fue el primer sistema en introducir las redes 3G, que mejoraron notablemente la velocidad de transmisión. Este sistema es un sucesor de la tecnología GSM o 2G.

1 INTRODUCCIÓN

Redes móviles

- **High Speed Packet Access (HSPA) o acceso a paquetes de alta velocidad:** esta red mejora la tecnología 3G aportando mayor velocidad a las comunicaciones, por lo que se le conoce como 3.5G. Esta tecnología permite extender y mejorar el rendimiento de las redes de las compañías móviles. Entre las evoluciones de HSPA destacan *High Speed Downlink Packet Access (HSDPA)*, que mejora en la velocidad de redes 3G, y *Evolved High Speed Packet Access (HSPA+)*, que incrementa aún más la velocidad.



1 INTRODUCCIÓN

Obtención de datos de la red telefónica

- ***Time Division Multiple Access (TDMA)* o acceso múltiple por división de tiempo:** esta tecnología introdujo conmutación en el tiempo de los canales de comunicación, pues permite que distintos usuarios compartan el mismo canal de frecuencia de la señal dividiéndola en diferentes intervalos de tiempo, sin que los usuarios interfirieran entre sí.
- ***Unlicensed Mobile Access (UMA)* o acceso móvil sin licencia:** esta red permite a cualquier servicio de telefonía establecer comunicación con cualquier tipo de redes IP, por lo que se puede utilizar junto con *bluetooth*, red wifi, etc. Por ejemplo, un usuario puede iniciar una llamada a través de su operador y cuando llega a la oficina se puede conectar automáticamente a la red wifi, lo cual reduce los costes de datos móviles.

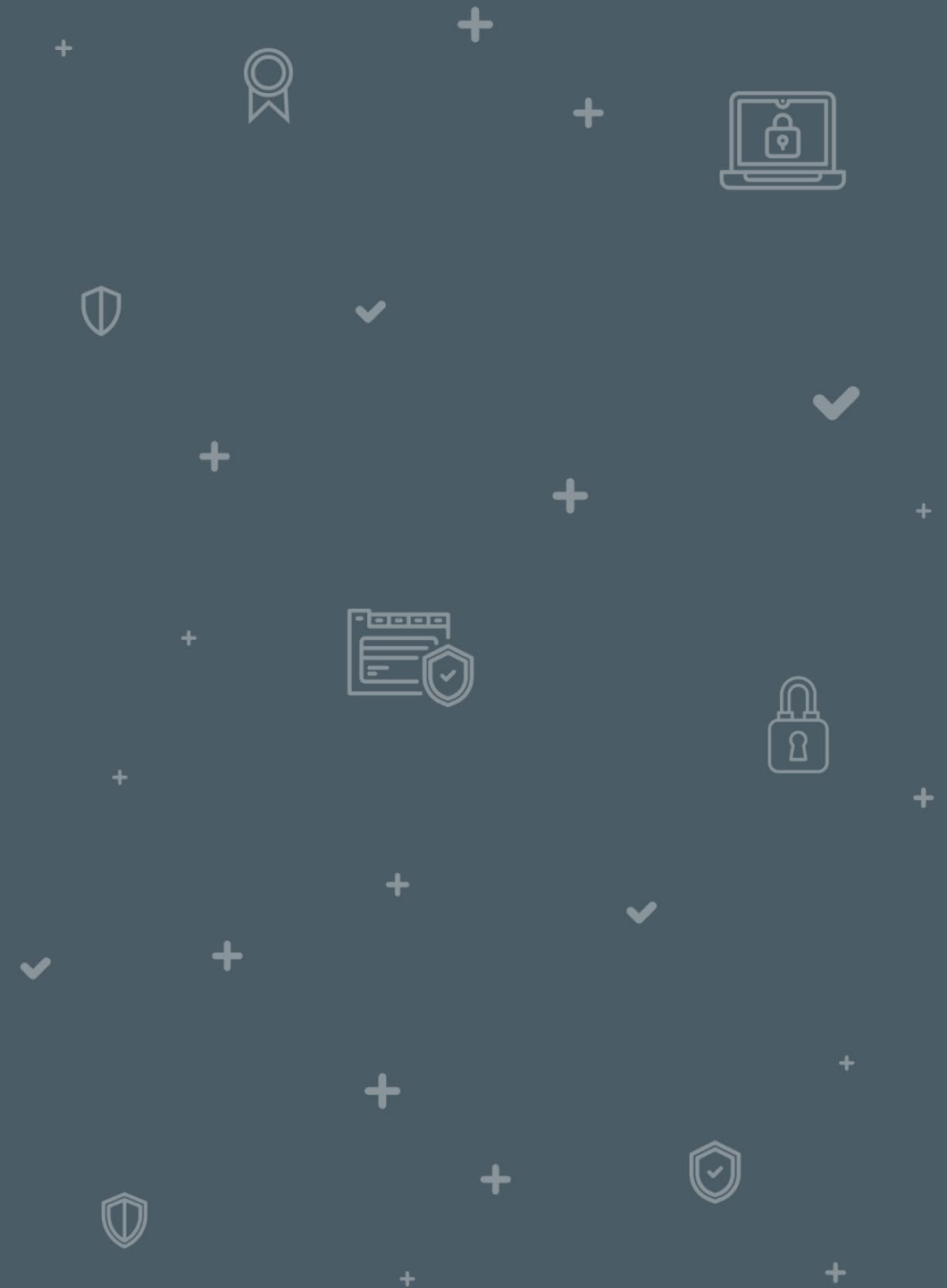
1 INTRODUCCIÓN

Obtención de datos de la red telefónica

- **Long-Term Evolution (LTE) o evolución a largo plazo:** muchas marcas comerciales equiparan LTE a 4G. Sin embargo, LTE incrementa en gran medida las velocidades existentes en las comunicaciones 3G y algunas compañías la consideran una red 3.9G. Más tarde, surgió LTE-Advanced, que sí se considera 4G. La principal diferencia entre ambas es su velocidad. Así, por ejemplo, si queremos descargar un vídeo de 700 MB, con la red LTE tardaría 20 segundos aproximadamente, mientras que con la red LTE-Advanced o 4G solo serían 6 segundos.
- **Voice over Long-Term Evolution (LTE):** esta tecnología se utiliza para realizar llamadas telefónicas y videollamadas.
- **La red 5G:** como ventajas de esta tecnología destaca el aumento de la velocidad de la red, llegando a ser entre 10 y 20 veces más rápida que el 4G.

2

SEGURIDAD EN DISPOSITIVOS MÓVILES



2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Tipos de vulnerabilidades

Es importante comprender y conocer las vulnerabilidades que tienen los dispositivos móviles, dado que muchas veces un incidente suele ser provocado por una de ellas y conocerlas puede ayudar a la hora de realizar un análisis forense.

Algunas de las vulnerabilidades más comunes son:

- **Vulnerabilidades en las aplicaciones:** dado el escaso tiempo que se suele emplear en el desarrollo de las aplicaciones móviles que, generalmente, son creadas a través de herramientas *open source* y que se elaboran priorizando el mayor número de descargas del producto, en lugar de su seguridad, las aplicaciones pueden poseer un gran número de vulnerabilidades que favorecen el riesgo de sufrir un ciberataque. Por otro lado, a nivel de una organización, el control que suele haber sobre un móvil corporativo es menor en comparación con el de un ordenador corporativo, por lo que los empleados suelen ser más proclives a descargar aplicaciones no autorizadas por la entidad.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Tipos de vulnerabilidades

- **Vulnerabilidades en el sistema operativo:** los sistemas operativos de los dispositivos móviles también poseen vulnerabilidades que se deberían tener en cuenta a la hora de distribuirlos entre los empleados de una organización. Es importante resaltar que los dispositivos Android suelen tener un periodo de parcheo de vulnerabilidades más largo que los dispositivos iOS.

¿Sabías qué?

En mayo de 2021 se detectó una vulnerabilidad que ponía en peligro al 30 % de teléfonos Android. [\[2\]](#)



SEGURIDAD EN DISPOSITIVOS MÓVILES

Tipos de vulnerabilidades

- **Vulnerabilidades en la red:** se centra en aprovechar las vulnerabilidades de la interfaz de red de un dispositivo móvil, que por su propia naturaleza, requiere de estar conectado. Además, los dispositivos también se conectan a redes potencialmente peligrosas y no cuentan con el mismo nivel de seguridad de red que los ordenadores, los servidores, etc.
- **Vulnerabilidades en la web y en el contenido:** se centra en explotar el contenido de páginas web, vídeos y fotos para poder vulnerar la seguridad de aplicaciones y sistemas operativos, y lograr así un acceso no autorizado, es decir, se podría utilizar la descarga de un archivo o una imagen para poder llegar a vulnerar el dispositivo y conseguir el acceso a los datos del mismo.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

¿Cómo aprovechan los ciberdelincuentes estas vulnerabilidades?

Las formas más comunes que tienen los ciberdelincuentes de utilizar las vulnerabilidades anteriores son:

- **Ataques por ingeniería social:** la ingeniería social no es solo uno de los métodos más simples para obtener credenciales de acceso de forma fraudulenta, también es uno de los métodos más efectivos para engañar a los usuarios y que se descarguen *malware* en sus dispositivos.

¿Sabías qué?

Según un estudio realizado por Verizon, el 74 % de todos los ciberataques son por errores humanos donde se incluyen las campañas de *phishing*. [3]



SEGURIDAD EN DISPOSITIVOS MÓVILES

¿Cómo aprovechan los ciberdelincuentes estas vulnerabilidades?

- **Vulnerabilidades en aplicaciones:** una de las vulnerabilidades más importantes de los dispositivos móviles es la baja seguridad que tienen las aplicaciones que se pueden instalar, sin verificar si son seguras o no. Asimismo, en ocasiones, los usuarios descargan aplicaciones desde tiendas no oficiales, por lo que dichas aplicaciones pueden no ser legítimas y albergar *malware*.
- **Redes poco seguras:** las redes públicas wifi se consideran inseguras dado que no se puede comprobar quién está accediendo a la red o si alguien la está monitorizando. Así, los ciberdelincuentes pueden acceder a una red wifi pública y capturar los datos que envíen y reciban los usuarios cuando se conecten a ella, un ataque conocido como *Man-in-the-Middle*.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

¿Cómo aprovechan los ciberdelincuentes estas vulnerabilidades?

- **Dispositivos IoT:** hoy en día, cada vez son más los usuarios que poseen dispositivos IoT conectados a su dispositivo móvil. Estos dispositivos IoT, al necesitar conectarse a Internet, pueden ser fuente de posibles vulnerabilidades y, dado que estos dispositivos IoT están conectados a un dispositivo móvil, si se logra acceder al dispositivo IoT se puede aprovechar para ganar acceso al dispositivo móvil a través de este.
- **Ataques *spyware*:** la descarga de posibles *malware* como *spyware*, serviría para recolectar información del dispositivo sin el conocimiento ni el consentimiento del usuario y, si se trata de un móvil corporativo, información de una organización. Estos *malware* pueden descargarse simplemente haciendo clic en un anuncio fraudulento.



2 SEGURIDAD EN DISPOSITIVOS MÓVILES

¿Cómo aprovechan los ciberdelincuentes estas vulnerabilidades?

- **Pérdida del dispositivo móvil:** otra amenaza común es la pérdida del dispositivo móvil, lo cual puede ocasionar que el atacante obtenga acceso a la información del mismo y, por lo tanto, a los datos personales o de una organización con relativa facilidad.
- **Sistemas operativos desfasados:** cuanto más tiempo tarda en actualizarse el móvil, mayor es la ventana de exposición a las vulnerabilidades que se le han detectado y, por lo tanto, más posibilidades tiene el dispositivo de comprometerse y hacerse más susceptible a ser atacado.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes

Como hemos visto, podemos enfrentarnos a una serie de vulnerabilidades cuando utilizamos dispositivos móviles, pero también existen una serie de ataques que pueden estar dirigidos expresamente a uno o varios dispositivos móviles con la intención de obtener acceso a la información confidencial o comprometida que guarda.

Con la irrupción de los dispositivos móviles en el mercado, el número de ataques y sus variantes han ido aumentando progresivamente. De esta forma, hemos llegado a un escenario donde existen multitud de ataques con diferentes propósitos.

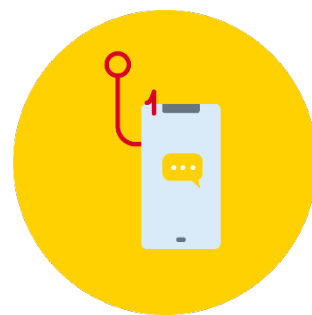
Por ello, realizar un análisis forense sobre estos dispositivos puede arrojar información acerca del tipo de ataque que se ha realizado, hasta dónde ha conseguido acceder y qué datos o información ha podido sustraer o se ha visto comprometida. De la misma forma, comprender todo esto puede ayudar a saber qué pasos o medidas tomar para proteger el dispositivo de dicho ataque.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *smishing*

El *smishing* es un ataque específico para teléfonos móviles en el que el atacante envía una serie de mensajes de tipo SMS haciéndose pasar por una fuente legítima. De este modo, el usuario cree que se trata de un mensaje real y accede al enlace que contiene el SMS.

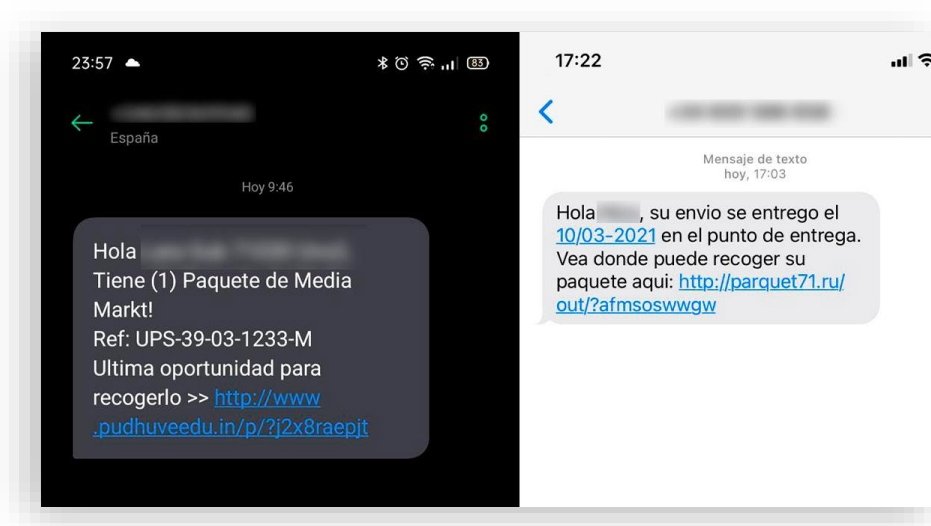
Dicho enlace redirige a una URL falsa con apariencia similar a la de la página web legítima que, habitualmente, contiene un formulario para que el usuario introduzca su usuario y contraseña. Al introducir estos datos, el atacante los recibe y puede utilizarlos para llevar a cabo actividades fraudulentas.



2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *smishing*

En la imagen inferior podemos observar un claro ejemplo de un *smishing*. En este tipo de ataques es muy común el uso de acortadores de URL como bit.ly, cutt.ly, etc., que imposibilitan que se pueda conocer desde el principio la URL de destino y, al pulsar en el enlace acortado del mensaje, en realidad se redirige a una página maliciosa.



Saber más: acerca del *smishing*. [4]

Fuente: *Ejemplos de campañas de smishing*. [Captura de pantalla] Extraído de <https://cronicaglobal.elespanol.com>

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *overlay*

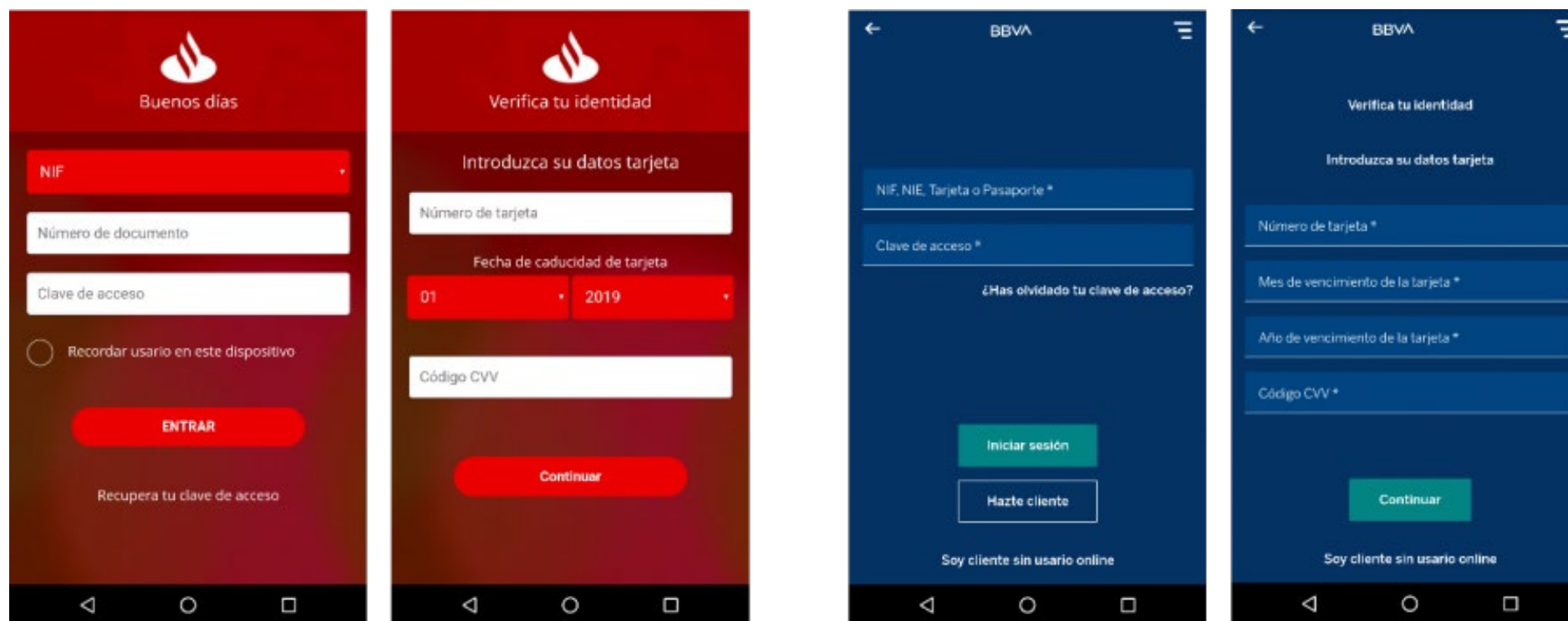
El ataque *overlay* o superposición de pantallas es una técnica muy utilizada por los ciberdelincuentes para el robo de credenciales en dispositivos Android. Únicamente afecta a dispositivos Android debido a que el *malware* aprovecha una biblioteca de Android para accesibilidad llamada Android Accessibility Services.

Este ataque consiste en un *malware* que se ejecuta en segundo plano y, cuando un usuario abre una aplicación que se encuentra en el listado del *malware*, este modifica la pantalla de credenciales mostrando una falsa, con el objetivo de obtener esos datos de acceso, es decir, si el dispositivo del usuario está infectado con dicho *malware*, cuando intenta acceder a la aplicación, el *malware* actúa y superpone una pantalla falsa con apariencia legítima para robar sus credenciales.

Este tipo de técnicas se utiliza generalmente en aplicaciones bancarias, con el objetivo de robar las credenciales de acceso.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: overlay



Fuente: *Ejemplos de campañas de overlay* [Captura de pantalla]
Extraído de <https://labs.f-secure.com/>

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: ataque a la red wifi de tipo WEP

WEP (del inglés, *Wired Equivalent Privacy* o privacidad equivalente a cableado) es un algoritmo de seguridad para redes inalámbricas que se utiliza para brindar seguridad a dichas redes. Este método se basa en no utilizar la misma clave dos veces para brindar una mayor seguridad de acceso.

Sin embargo, este algoritmo es antiguo y en varios ataques se demostró que era fácilmente explotable, consiguiendo así que se generase una gran cantidad de paquetes. Así, con esta información se podía descifrar la clave de la red.

Por ello, es importante no conectarse a redes wifi que posean el algoritmo WEP, ya que sería sencillo para un atacante descifrar la clave y comprometer el sistema, aunque WEP está completamente en desuso actualmente, ya que fue reemplazado por WPA.



¿Sabías qué?

El sistema WEP se introdujo en 1997 y fue el primer intento de protección inalámbrica. [\[5\]](#)

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: ataque a la red wifi de tipo WPA

WPA (del inglés, *Wi-Fi Protected Access* o acceso Wi-Fi protegido) es un protocolo de seguridad de redes wifi que se diseñó como sustituto para el protocolo WEP que, como hemos mencionado, tenía algunos fallos de seguridad.

Este protocolo mantiene similitudes con el protocolo WEP, pero ofrece algunas mejoras en la gestión de claves de seguridad y la autorización de los usuarios.

Sin embargo, el protocolo WPA es susceptible a los ataques de fuerza bruta para descifrar la contraseña de la red, por lo que se han ido implementando varios algoritmos de mejora:

- **WPA2:** más adelante, se comprobó que también había logrado comprometerse, por lo que dejó de ser un algoritmo seguro para los usuarios.
- **WPA3:** actualmente es considerado el algoritmo más seguro aunque lleve pocos años en funcionamiento.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: ataque a la red wifi de tipo WPA

Con este tipo de ataques, lo que puede suceder es un robo de información. Sin embargo, con el uso de HTTPS este robo es menos sencillo, ya que en caso de que un atacante lograra capturar el tráfico de red, este se encontraría cifrado.

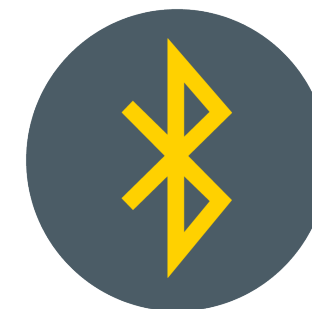


2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: a través de *bluetooth*

Cuando utilizamos un dispositivo y tenemos el *bluetooth* activado, debemos tener en cuenta que, desde ese momento, somos susceptibles a ciertos riesgos y ataques. Algunos de ellos son:

- *Bluejacking*: es un tipo de ataque en el que se utiliza las capacidades del *software bluetooth* para enviar mensajes no autorizados o solicitados a otro dispositivo que también tenga el *bluetooth* activado y se encuentre dentro de su ratio de alcance. Aunque no siempre es peligroso, ya que puede llevarse a cabo con el fin de enviar mensajes o textos, también puede ser utilizado para desplegar *malware*. Por ejemplo, si se recibe publicidad maliciosa y el usuario hace clic en el enlace, se podría llegar a descargar *software* malicioso comprometiendo el dispositivo.



2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: a través de *bluetooth*

- En caso de conseguir comprometer el dispositivo, a continuación se utiliza la técnica denominada *bluesnarfing*, que consiste en el robo de información de los usuarios a través de la conexión *bluetooth* de su dispositivo. El ciberdelincuente envía archivos maliciosos a través del *bluetooth* al dispositivo del usuario, pudiendo infectarlo y afectar a su funcionamiento para obtener datos personales.
- El ataque *bluebugging* se basa en un *exploit* que puede generar una puerta trasera en el dispositivo del usuario que esté utilizando el *bluetooth*, a través de la cual puede robar sus datos, enviar archivos maliciosos, etc. Es un método muy utilizado para espiar al usuario.
- El ataque *bluesmacking* es ataque de denegación de servicio (DoS) en el que el atacante envía múltiples solicitudes a los que el servicio de *bluetooth* no puede hacer frente, consiguiendo así afectar al correcto funcionamiento o rendimiento del dispositivo.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: a través de *bluetooth*

Dado que el *bluetooth* es una tecnología de corto alcance, este tipo de ataques solo podrán realizarse estando cerca de la víctima, ya que, en caso contrario, no se podría establecer la conexión.

Estos son solo algunos de los ataques que se puede producir a través de dispositivos que utilizan la tecnología *bluetooth*.



Saber más: sobre ataques *bluetooth* [\[6\]](#) y sobre seguridad *bluetooth* [\[7\]](#).

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *replay attack*

Este tipo de ataque se centra en espiar las comunicaciones que se están llevando a cabo entre dos dispositivos, interceptar los paquetes de comunicación para retrasar el envío o reenviar mensajes modificados para que el receptor lleve a cabo las acciones que el atacante le solicite.

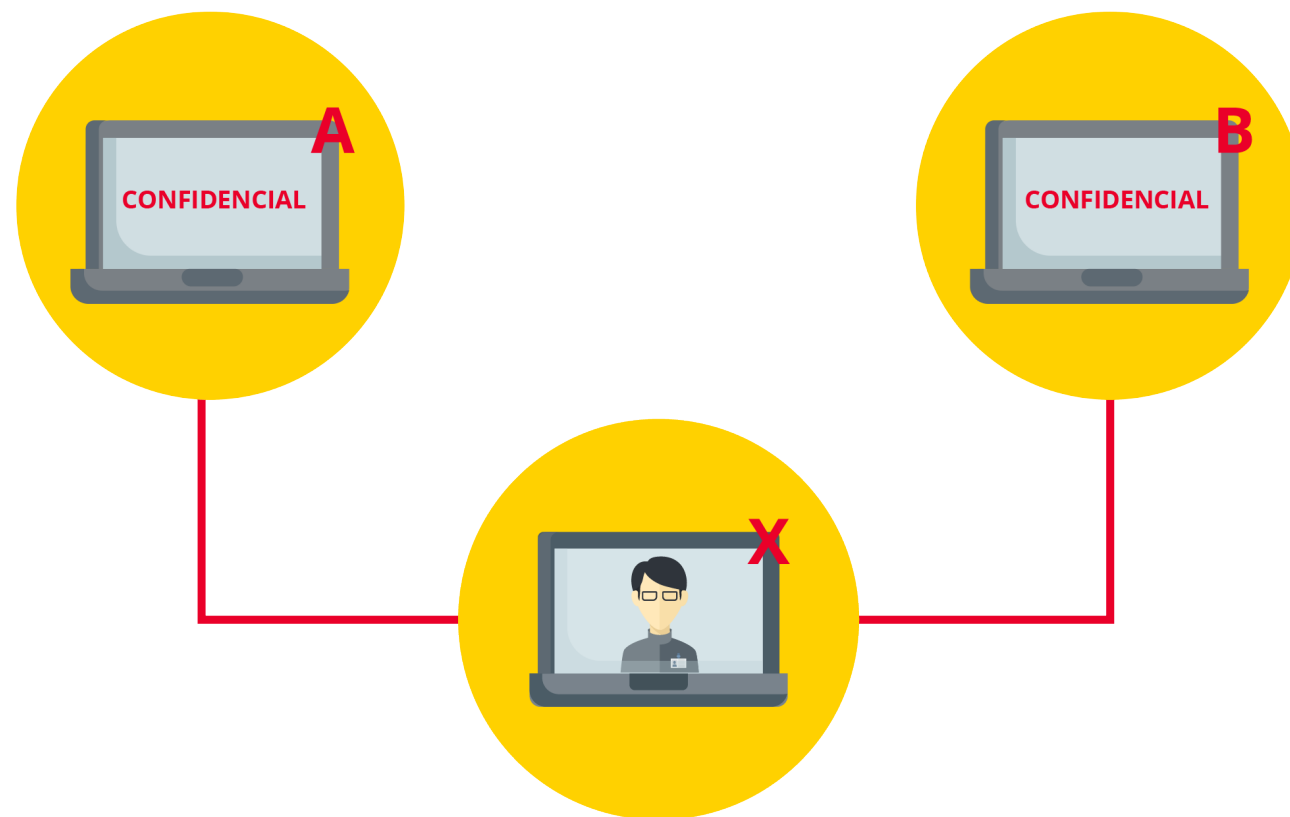
La técnica más utilizada para este tipo de ataques es conocida como *Man-in-the-Middle*. Un atacante se sitúa entre el emisor y el receptor interceptando los paquetes, reenviándolos suplantando alguna identidad y pudiendo así comprometer la confidencialidad y la integridad de una comunicación entre dos dispositivos.



Saber más: sobre el ataque *Man-in-the-Middle*. [\[8\]](#)

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *replay attack*



Fuente: *Ejemplo funcionamiento Man in the Middle* [Gráfico] Adaptado de <https://www.incibe.es>

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *RF jamming*

RF jamming o *radio frequency jamming* es un ataque que afecta directamente a la disponibilidad de las comunicaciones inalámbricas de los dispositivos.

En este ataque se envía una potente señal de radio para inundar con ruido blanco las bandas de frecuencia utilizadas por los dispositivos. El ruido blanco es una señal de sonido que contiene todas las frecuencias audibles que existen, con la misma amplitud, por lo que son sonidos planos y constantes como el que puede hacer una televisión o una radio sin sintonizar. De este modo, el dispositivo no será capaz de distinguir las señales legítimas de las generadas por el atacante y, por lo tanto, no conseguirá establecer ninguna comunicación.

En este tipo de ataque también es necesario que el atacante esté cerca de la víctima para poder afectar sus comunicaciones. Se realiza a través de inhibidores de señal y su uso de forma normal no está permitido.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *clickjacking*

Este ataque también es conocido como ataque de compensación de UI (del inglés, *User Interface* o interfaz de usuario). Se utiliza en la actualidad debido a la gran cantidad de páginas web que suelen visitar los usuarios a diario. El ataque consiste en la instalación de un contenido o enlace invisible en los sitios web donde el usuario pueda hacer clic de forma involuntaria. De este modo, el enlace invisible redirige al usuario a todo tipo de páginas web maliciosas.

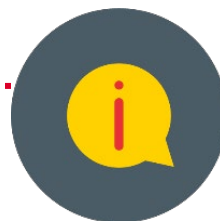
Para evitar este tipo de ataques se debe tratar de acceder únicamente a sitios oficiales, ya que, aunque no se garantiza que puedan no estar comprometidos, siempre tienen una mayor implementación de medidas de seguridad. Sin embargo, también existen extensiones o complementos en los navegadores que se encargan de evitar el ataque.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *clickjacking*

¿Sabías qué?

Un ataque de *clickjacking*, conocido como Svpeng, fue un troyano que se distribuía a través de páginas web maliciosas y, una vez activado en los terminales Android, solicitaba permisos de acceso. A través de técnicas de *clickjacking* conseguía hacerse con datos de los dispositivos. Se estimó que en tan solo una semana, Svpeng se extendió a 23 países. [\[9\]](#)



2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: *spyware*

El ataque *spyware*, tal y como vimos en la unidad 2, consiste en un programa de *software* que recoge los datos sobre el usuario o su actividad en el dispositivo móvil sin el conocimiento y/o consentimiento de este.

Uno de los *spyware* más famosos fue Pegasus, diseñado principalmente para espiar los dispositivos móviles, tanto de Android como iOS. Este *malware* aprovecha las vulnerabilidades *zero-day* del *software* que han sido descubiertas por agentes maliciosos antes que por el propio proveedor, por lo que todavía no existe parche o actualización que las corrija. Por lo tanto, aprovechan esta oportunidad para instalarse en los móviles y conseguir así el control total sobre el dispositivo para monitorizar todas las actividades que se realicen en él sin ningún conocimiento por parte del usuario.

Para propagar el virus se utiliza ingeniería social.



Saber más: sobre Pegasus. [\[10\]](#)

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: tiendas de aplicaciones no oficiales y reempaquetado de aplicaciones

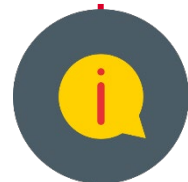
Las tiendas de aplicaciones son también un objetivo para los ciberdelincuentes, cuyo fin es distribuir *malware* entre los dispositivos e instalar en ellos aplicaciones maliciosas. Un caso muy común consiste en que los atacantes descargan una aplicación legítima, realizan ingeniería inversa sobre ella, instalan *malware* y la suben a tiendas de terceros donde los usuarios pueden descargarlas, creyendo que son legítimas o seguras. Esto es lo que se conoce como reempaquetado de aplicaciones.

Estas tiendas de terceros no suelen estar protegidas ni disponen de filtros que revisen las aplicaciones por lo que, un análisis insuficiente o nulo suele dar lugar a aplicaciones maliciosas y falsas que pueden provocar daños en el sistema operativo o en la información almacenada, e incluso podrían instalar programas adicionales afectando al rendimiento y correcto funcionamiento del dispositivo o utilizar el dispositivo para realizar otros ataques.

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

Ataques comunes: tiendas de aplicaciones no oficiales y reempaquetado de aplicaciones

Esto no significa que las tiendas oficiales de aplicaciones estén exentas de riesgos, pero están reducidos debido al minucioso control y análisis que se llevan a cabo en ellas. En caso de reportar una aplicación como maliciosa, esta se elimina rápidamente de la tienda.



¿Sabías qué?

En 2022 se descubrió una aplicación de autenticación 2FA (doble factor) troyana en una tienda de aplicación que ya se había instalado más de 10.000 veces hasta que se retiró. [\[11\]](#)

2 SEGURIDAD EN DISPOSITIVOS MÓVILES

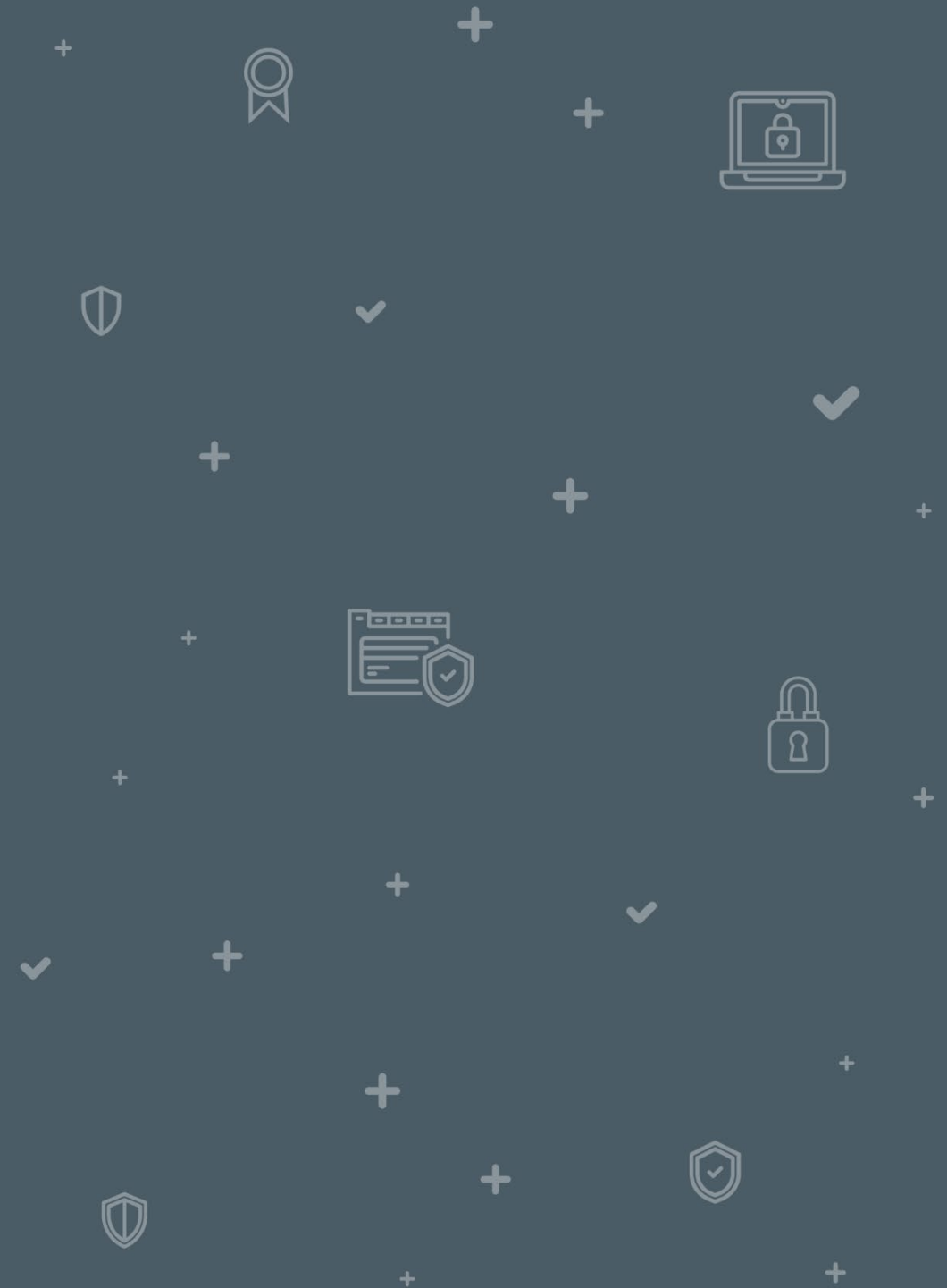
Herramientas: criptografía

Como se ha mencionado anteriormente, la encriptación es una parte esencial para mantener la seguridad de los datos en los dispositivos móviles. Por norma general, los usuarios tratan de una manera menos segura sus datos en estos dispositivos. Por ello, muchas aplicaciones y proveedores ofrecen servicios de encriptación en los que la información es almacenada de forma segura para evitar su utilización maliciosa.

Los responsables de implementar todas estas medidas criptográficas son los desarrolladores y los fabricantes de los dispositivos, pero para poder realizar un análisis óptimo de los mismos es importante conocer una serie de fundamentos de criptografía.

3

ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Artefactos en investigación forense en dispositivos móviles

Como hemos explicado en la unidad de análisis forense digital, los artefactos son una parte esencial de un análisis forense, es decir, hacen referencia a los diferentes ficheros, rutas y configuraciones que pueden determinar si ha ocurrido una incidencia.

Se ha de tener en cuenta que un dispositivo móvil puede tener varias fuentes para un mismo artefacto, como la tarjeta SIM, las memorias extraíbles o el almacenamiento interno del dispositivo. Algunos de los artefactos más relevantes que podemos encontrar en un dispositivo móvil son:



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Artefactos en investigación forense en dispositivos móviles

- **Contactos y llamadas realizadas:** dependiendo de la clase de dispositivo móvil que estemos utilizando podremos encontrar la lista de contactos y la lista de llamadas en diferentes ubicaciones.

En los dispositivos Android tanto la lista de llamadas como los contactos se encuentran en la misma base de datos: **/data/data/com.Android.providers.contacts/databases/contacts2.db**.

Sin embargo, en iOS encontramos los contactos en **\private\var\mobile\Library\AddressBook** y el historial de llamadas en **\private\var\mobile\Library\CallHistory**.

- **Mensajes SMS:** el listado de todos los mensajes que se han mandado desde el dispositivo se podrá encontrar en la memoria interna del **dispositivo** **/data/data/com.Android.providers.telephony/databases/mmssms.db** y en la tarjeta SIM. En los dispositivos iOS este listado está ubicado en **Library/SMS/sms.db**.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Artefactos en investigación forense en dispositivos móviles

- **Archivos multimedia:** todos los archivos multimedia del dispositivo, como imágenes o vídeos, pueden ser información relevante para una investigación. Cada uno de estos archivos puede tener metadatos que puedan dar información de cuándo se hizo la imagen o se grabó el video, etc. Dependiendo de la aplicación donde se haya generado el archivo multimedia, se guardará en diferentes ubicaciones. Por ejemplo, si hemos obtenido una imagen a través de una aplicación de mensajería instantánea, esta se guardará en una carpeta específica relacionada con esa aplicación. Para los archivos iOS, estos siempre se guardarán en el almacenamiento interno del dispositivo dado que no cuentan con memorias extraíbles y se pueden encontrar en **`\private\var\mobile\Media\`**.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Artefactos en investigación forense en dispositivos móviles

- **Lista de aplicaciones instaladas:** en los dispositivos Android podremos encontrar esta información dentro del **fichero /data/system/packages.xml**. En iOS, si se trata de aplicaciones propias del iPhone, se ubican en **\private\var\stash\Applications**, mientras que si son instaladas con iTunes se ubican en **\private\var\mobile\Applications**
- **El historial de aplicaciones:** el historial del acceso a las aplicaciones instaladas en el dispositivo es una información que puede resultar interesante para el analista forense durante una investigación. En los dispositivos Android esta información se encuentra en el fichero **/data/system/usagestats/usage-history.xml**. En los dispositivos iOS encontraremos gran parte de esta información en **/private/var/mobile/Library/Preferences**.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Artefactos en investigación forense en dispositivos móviles

- **Cuentas:** todas las cuentas que se hayan guardado en el dispositivo se encuentran almacenadas en la memoria interna del dispositivo, tanto los usuarios como contraseñas de acceso, por ejemplo, de redes sociales. En los dispositivos Android esta información está localizada en la siguiente ruta: **/data/system/users**. En iOS se encuentra información en **/private/var/Keychains**.
- **Conexión de red:** la información del proveedor de la línea se encuentra almacenada en el dispositivo. En este sentido, podemos encontrar información de las últimas torres de la red a las que se ha conectado, lo que nos permitirá ubicar todos los movimientos del dispositivo. En los dispositivos Android esta información está localizada en la siguiente ruta: **/data/data/com.Google.Android.location/files/cache.cell**. En los dispositivos iOS encontraremos esta información en **/var/wireless/Library/Logs**, y en **/private/var/preferences/SystemConfiguration** también encontraremos información relevante acerca de conexiones red.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Artefactos en investigación forense en dispositivos móviles

- **Conexiones de redes wifi:** la información de los últimos puntos de acceso wifi a los que se ha conectado el dispositivo también queda almacenada. En los dispositivos Android esta información está ubicada en **`/data/data/com.Google.Android.location/files/cache.wifi`**. En los dispositivos iOS encontraremos esta información en **`/var/wireless/Library/Logs`**.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Proceso de análisis forense: diferencias entre un ordenador y un dispositivo móvil

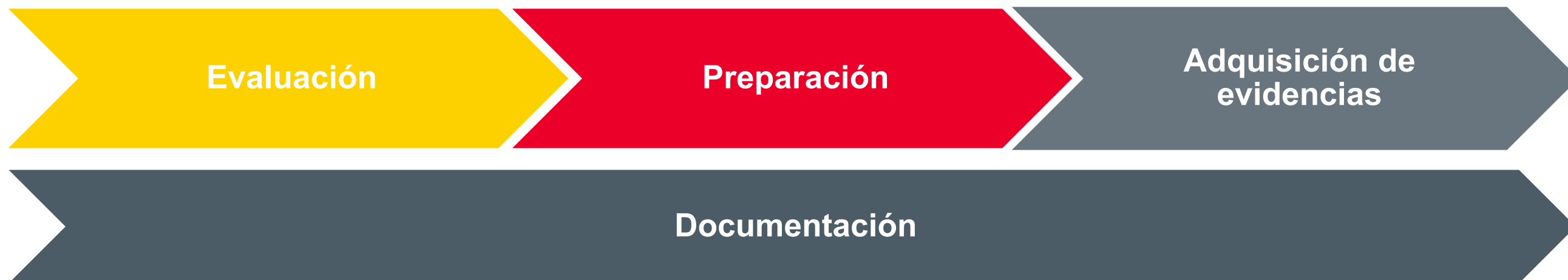
Aunque el proceso de análisis forense es el mismo entre un ordenador y un dispositivo móvil, existen algunas diferencias que se deben tener en cuenta:

	Ordenador	Dispositivo móvil
Fuente de evidencias	Disco duro, RAM, memorias extraíbles.	Tarjeta SIM, RAM, ROM, memoria externa, datos de red.
Adquisición de los datos	Se trata de dispositivos de almacenamiento estático, por lo que siempre se obtiene la misma imagen.	Se trata de dispositivos dinámicos, por lo que la imagen cambia cada vez, ya que se recuperan solo los archivos existentes en el dispositivo o cada byte de la RAM.
Conservación de los datos	Si el ordenador se apaga, su estado se conserva porque ya no se necesitaría volver a encenderlo. Las evidencias son menos volátiles.	Los dispositivos móviles deben encenderse para recopilar los datos, lo que a su vez puede alterar el estado del dispositivo. Las evidencias son más volátiles.
Sistema de archivos	Dispone de un sistema de archivos estándar.	Existe una amplia gama de sistemas de archivos.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Proceso de análisis forense: fases

Las fases que se llevan a cabo durante una investigación forense en un dispositivo móvil son muy similares a las que se realizan en un análisis forense convencional, salvo alguna excepción:



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Evaluación

El primer paso que se deberá realizar en una investigación forense en dispositivos móviles consiste evaluar la situación, las posibles evidencias que se recopilarán posteriormente. Además, es necesario pedir autorización para poder proceder y actuar, además de revisar las políticas y la legislación que se aplicará en cada caso.

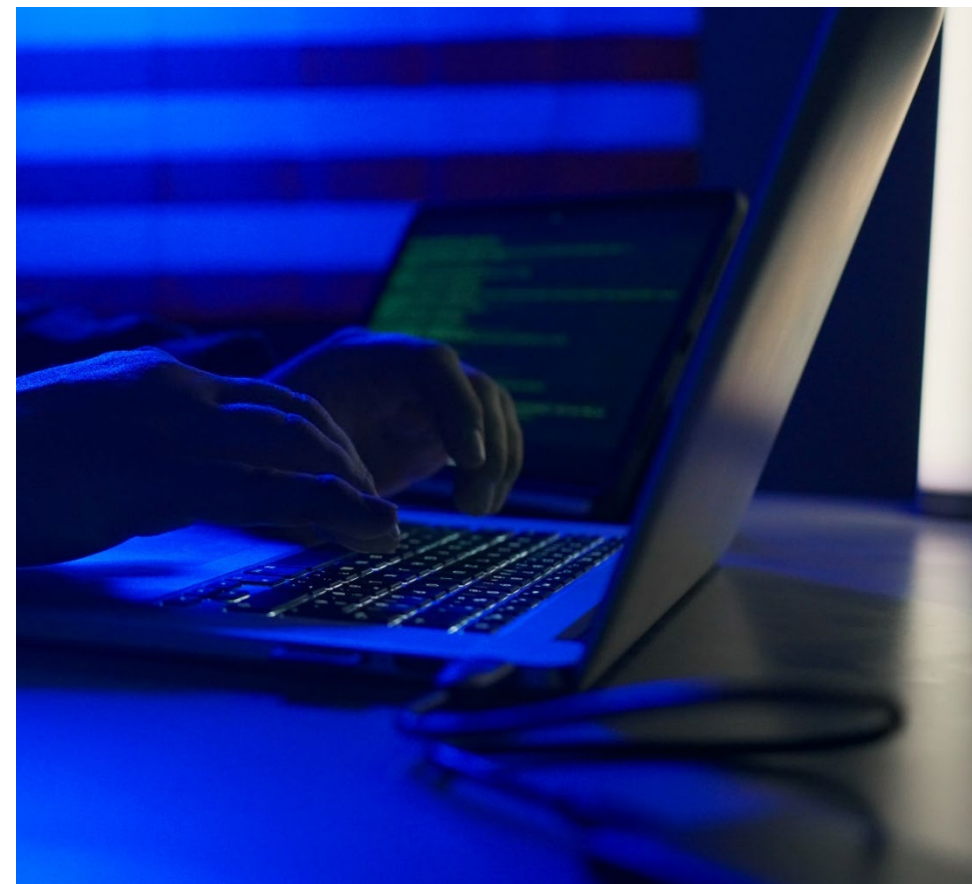
Se identificará físicamente el dispositivo que se pretende analizar. Esto lleva a tener en cuenta diversos factores, como el tipo de dispositivo móvil, que puede ser un GPS, un teléfono móvil, una tableta, etc.; la marca del dispositivo; el modelo del dispositivo, y el proveedor del servicio.

Además, existe otra serie de datos interesantes que se pueden obtener mientras se identifica el dispositivo móvil, como la interfaz del dispositivo (la pantalla de usuario que le permite interactuar con el dispositivo), que aportará información en caso de que se encuentre encendido; el número de serie; la hora y fecha configuradas en el dispositivo, y el *software* de sincronización.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Evaluación: Obtención de la información

Obtener la información de identificación preliminar es muy importante porque si no identificamos el dispositivo móvil a simple vista, puede que algunos ciberdelincuentes hayan intentado obstruir el proceso de la investigación alterando el dispositivo y llevar a los analistas forenses a la confusión. Este tipo de alteraciones puede ser quitar las etiquetas del manufacturado o los logos del dispositivo móvil, e incluso que el sistema operativo del dispositivo haya sido completamente reemplazado.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Preparación: Materiales

Antes de comenzar con la fase de recolección de evidencias, es importante asegurar que las evidencias digitales se preservan correctamente durante la realización del proceso de análisis forense. Para ello, dadas las continuas comunicaciones inalámbricas entre los dispositivos móviles, se debe disponer de los recursos adecuados para almacenar las evidencias. Algunos de los métodos de preservación son los siguientes y todos estos elementos serán imprescindibles en el kit de un analista forense:

- **Bolsa de Faraday:** consiste en introducir un dispositivo móvil en el interior de esta bolsa que previene el riesgo de que señales externas puedan sobrescribir o borrar los datos existentes.
- **Latas de metal contra incendio:** este método previene de que el dispositivo pueda sufrir daños en caso de incendio y también impide las comunicaciones inalámbricas.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Preparación: Materiales

- **Papel de aluminio:** es conveniente para preservar evidencias siempre que se utilicen, al menos, tres capas de este material para cubrir el dispositivo.
- **Bolsas blindadas antiradiofrecuencia:** su funcionamiento es similar a las descritas anteriormente y disponen de varios medios, como memorias externas o USB para la extracción de evidencias.
- **Cualquier otro tipo de bolsas o cajas que impidan las conexiones inalámbricas:** su función es similar a la bolsa de Faraday anterior. Estas bolsas deberán estar homologadas por el equipo de análisis forense verificando que impiden las conexiones inalámbricas.
- **Inhibidores locales:** su uso sirve para emitir un ruido blanco que imposibilita las comunicaciones del dispositivo. Dicha emisión de ruido siempre debe realizarse en un entorno controlado y autorizado.

Una vez se dispone de todos estos recursos, se puede proceder a la adquisición de las evidencias.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: Introducción

Esta fase de adquisición de evidencias podemos dividirla en dos subfases:

- Adquisición de evidencias del dispositivo.
- Adquisición de evidencias de aplicaciones.



ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: fuentes

Los datos de un dispositivo móvil se pueden almacenar en cuatro lugares diferentes que servirán como fuente a la hora de obtener información de las evidencias digitales:

- **La tarjeta SIM:** contiene información de la lista de contactos, mensajes e información relativa al servicio de telefonía.
- **La memoria interna:** contiene los datos almacenados en el dispositivo, la memoria RAM y la memoria ROM.
- **La memoria externa:** hace referencia a la tarjeta SD o microSD que se suelen utilizar para ampliar el almacenamiento del dispositivo.
- **El almacenamiento en la nube:** actualmente, gran cantidad de los datos de los usuarios se almacenan en la nube, en iCloud en el caso del sistema operativo iOS o en Google Drive en el caso de dispositivos Android.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: recolección

Al igual que con todo tipo de análisis forense, es importante la adquisición de evidencias, su transporte, su correcta preservación y su procesamiento final, manteniendo siempre la cadena de custodia que ayudará a llevar una documentación que acredite que la evidencia no ha sufrido ninguna modificación durante todo el trascurso de la investigación.

En la fase de recolección de evidencias, en este caso, un dispositivo móvil, existen dos grandes problemáticas:

- El dispositivo puede que haya sido bloqueado de alguna forma, tanto por el sospechoso como por terceros.
- El dispositivo puede haber sufrido alguna pérdida de datos o evidencias por una conexión remota u otros tipos de conexiones que reciba o realice el dispositivo durante su manejo.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: recolección

Para evitar que el dispositivo sea modificado por una conexión externa y así poder perder información importante para la realización del análisis forense, se deberá aislar el dispositivo correctamente. Esto puede llevarse a cabo de dos maneras, bien activando el modo avión del dispositivo y desconectando todas las diferentes formas de conexión externas de las que disponga el equipo, como la red wifi, la conexión infrarroja, etc., e introduciéndolo en una caja Faraday; o bien realizando un clonado de la tarjeta SIM, evitando así perder información vital para la realización del análisis forense, dado que, si bien la mayoría de las evidencias dentro de la tarjeta SIM no son volátiles, algunas sí lo son, como los últimos números marcados, por ejemplo, y estas se deben preservar. En toda investigación forense se deberá crear una copia de la memoria para poder investigar sobre ella mientras que la prueba original se mantiene intacta.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: estado del dispositivo

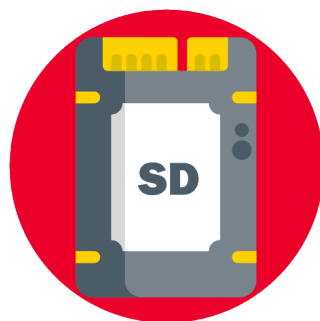
Por otro lado, es importante comprobar el estado en el que se encuentra el dispositivo:

- Si el dispositivo está apagado, únicamente se deberá mantener en buen estado para su posterior análisis. No será necesario mantener el dispositivo en una bolsa Faraday, pero se deberá tener en cuenta que el dispositivo deberá encontrarse en un entorno aislado si se va a encender, evitando así que el dispositivo se pueda modificar por conexiones externas según se encienda.
- Si el dispositivo está dañado, se deberá realizar el análisis JTAG (del inglés, *Join Test Action Group*) o *Chip Off*. Se trata de dos métodos que permiten acceder directamente a la memoria no volátil cuando un dispositivo no se enciende o no se puede terminar la carga del sistema operativo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: estado del dispositivo

- Si el dispositivo está encendido, en primer lugar, se comprobará si existe una tarjeta SIM y una tarjeta de memoria para extraer los datos y, a continuación, se comprobará el estado del dispositivo. Si el dispositivo está bloqueado, se conectará a la corriente para evitar que se apague; si, por el contrario, está desbloqueado, se activará el modo avión y cualquier otra opción necesaria para que no se bloquee de nuevo.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: desbloqueo de dispositivos Android

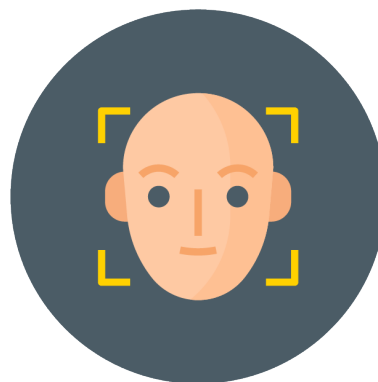
En caso de que el estado de un dispositivo Android aparezca bloqueado, se podría desbloquear a través de las siguientes opciones:

- **Por contraseña:** es un código de entre 4 y 16 caracteres que puede contener letras, números y caracteres especiales. Un analista forense podrá saltarse este tipo de bloqueo mediante ataques de fuerza bruta.
- **Por patrón de desbloqueo:** se trata de una especie de figura que el usuario dibuja en una cuadrícula, habitualmente, de 3x3. En caso de coincidencia exacta con el patrón, el dispositivo móvil se desbloqueará. Un analista forense podrá rootear el dispositivo y acceder a la carpeta de *gesture.key* donde se almacenará este patrón y, utilizando una herramienta como Android Patern Lock Crack Pattern, nos indicará este patrón pudiendo así desbloquear el dispositivo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: desbloqueo de dispositivos Android

- **Por código PIN:** se trata de un código numérico que, habitualmente, consta de 4 caracteres para desbloquear el dispositivo. Un analista forense podrá saltarse este tipo de bloqueos mediante ataques de fuerza bruta.
- **Por datos biométricos:** hacen referencia a diferentes datos biométricos implementados por el fabricante del dispositivo, como el reconocimiento facial, el lector de huellas, etc. Un analista forense podrá utilizar herramientas como Frida para saltarse este tipo de bloqueos, así como algunos de los bloqueos anteriormente explicados.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: desbloqueo de dispositivos iOS

En caso de que el estado de un dispositivo iOS aparezca bloqueado, se podría desbloquear a través de las siguientes opciones:

- **Por código numérico:** se trata de un código numérico de 4 o 6 dígitos que protege el acceso al dispositivo móvil. Un analista forense podrá saltarse este tipo de bloqueos mediante la utilización de ataques de fuerza bruta o mediante la utilización de aplicaciones de *jaibreaking*, un método que permite la escalada de privilegios dentro de un dispositivo iOS, como checkra1n.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: desbloqueo de dispositivos iOS

- **Por reconocimiento facial o *Face ID*:** se trata de una tecnología implementada gracias a varios sensores que renderizan un modelo 3D del rostro y permiten el desbloqueo en caso de coincidencia exacta con el mismo. El reconocimiento facial permite desbloquear el dispositivo por código en caso de error de identificación facial. Un analista forense podrá utilizar *jailbreaking* para saltarse este bloqueo o, si no es posible el desbloqueo mediante *jailbreaking*, se deberá pedir al usuario si puede entregar los accesos al dispositivo.
- **Por sensor de huella dactilar o *Touch ID*:** se trata de un lector de huellas implementado en el botón de inicio del dispositivo. Este sensor también permite el desbloqueo por código si la huella no coincide con la que había sido almacenada previamente. Un analista forense podrá utilizar *jailbreaking* para saltarse este bloqueo o se deberá pedir al usuario si puede entregar los accesos al dispositivo.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: volátiles y no volátiles

Como hemos mencionado anteriormente, es necesario tomar precauciones a la hora de recolectar los dispositivos móviles como evidencias. En este sentido, se deberá diferenciar entre evidencias volátiles y evidencias no volátiles, tal y como vimos en la unidad de análisis forense digital.

- **Evidencias volátiles:** en el caso de los dispositivos móviles, las evidencias son incluso más volátiles que en otros tipos de dispositivos debido a su naturaleza móvil y a su interconectividad con uno o más repositorios en la nube. Por ello, se deberá utilizar una serie de herramientas para mantener la integridad del dispositivo, como la utilización de bolsas de Faraday para evitar cualquier tipo de perturbación en las evidencias.

ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: volátiles y no volátiles

- **Evidencias no volátiles:** estas evidencias pueden ser extraídas directamente de cualquier dispositivo de almacenamiento y no se perderían al apagar un sistema. Por lo tanto, el analista forense deberá tener en cuenta que no será necesario preocuparse por la extracción de estas evidencias hasta que lleguen al laboratorio forense, dado que el apagado del equipo o desconexión de la Red a la que esté conectado no va a resultar decisiva en la alteración o pérdida de estas evidencias, pero sí lo sería para las evidencias volátiles. Por ello siempre se deberán tomar todas las medidas necesarias para preservar las evidencias volátiles, aislar el dispositivo, evitar que se apague si es posible etc.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: recolección

Se deberá tener en cuenta que la información que se almacena dentro de un dispositivo móvil es muy fluctuante, es decir, no se suele guardar únicamente en él. Los contenidos también suelen estar sincronizados con repositorios en la nube, como iCloud o Google Drive, lo que podría dejar la puerta abierta para obtener información de estos alojamientos o que esta se pudiera modificar o eliminar.

Para realizar un análisis de sistemas en la nube se tendrán que tener en cuenta diversos factores, como la arquitectura del entorno en la nube o la zona geográfica en la que estén ubicados los servidores que proporcionan los servicios y, en consecuencia, las leyes y regulaciones vigentes del país al que pertenezca la ubicación de la nube.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: recolección

Por otro lado, la existencia de móviles genéricos, móviles que no pertenecen a una marca específica y que suelen ser copias de móviles de otras marcas, tiene una gran prevalencia en el mercado de los dispositivos móviles debido a la competitividad de sus precios.

La falta de estandarización en el *hardware* y *software* que utilizan supone un problema a la hora de realizar un análisis forense, ya que la mayoría de las herramientas automatizadas no son capaces de extraer toda la información necesaria. Los análisis manuales también podrían complicarse dado que cada dispositivo puede estar configurado de manera diferente a cualquier otro. Por ello, para el análisis de estos dispositivos se recomiendan herramientas especializadas, como UFED Chinex Kit.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

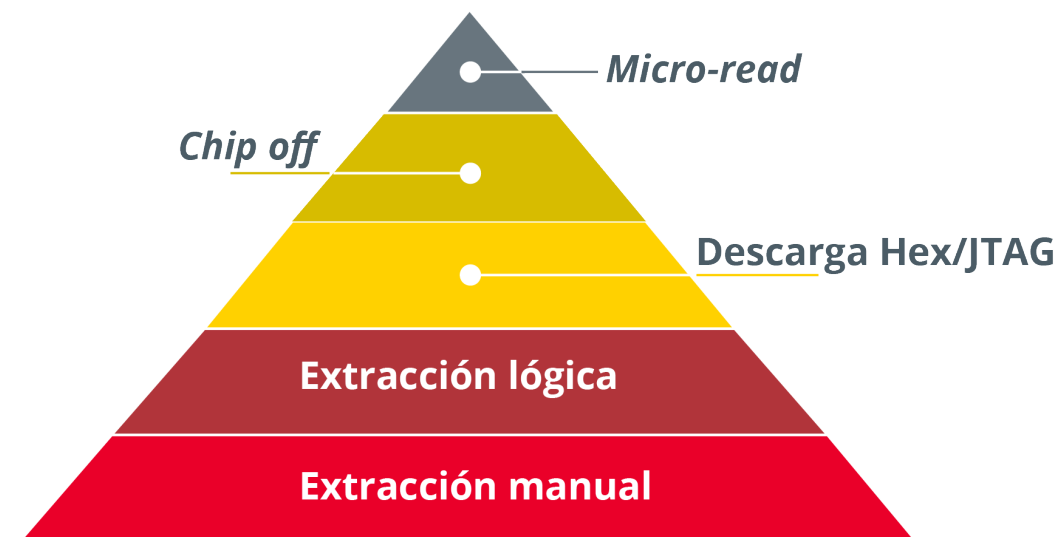
Adquisición de evidencias: métodos

A la hora de realizar una investigación forense se tienen que tener en cuenta las diferentes metodologías que existen tanto en el análisis forense no invasivo como invasivo. Los métodos no invasivos consisten en la obtención de evidencias sin interactuar con los componentes internos del dispositivo, mientras que los métodos invasivos consisten en obtener evidencias mediante la interacción con los componentes internos del dispositivo. El proceso de análisis siempre debería comenzar realizando un análisis no invasivo del dispositivo, obteniendo primero una imagen física, que consiste en recopilar toda la información que se puede extraer a través del *hardware* del dispositivo, y después una imagen lógica, es decir, la información lógica del dispositivo, la estructura de ficheros que está almacenado en el dispositivo, etc., ya que, de lo contrario, se podría borrar completamente la memoria del dispositivo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos

De igual modo sucede cuando intentamos acceder a un dispositivo bloqueado sin conocer la contraseña del mismo y realizamos varios intentos fallidos de acceso o interactuamos con los componentes internos del dispositivo, podríamos ocasionar daños en el mismo y hacerlo inservible.



Fuente: *Pirámide de clasificación de herramientas de análisis forense para dispositivos móviles* [Gráfico]

Adaptado de <https://www.incibe-cert.es>

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos no invasivos

Los métodos no invasivos de análisis forense son todos aquellos métodos que no interaccionan con los componentes internos de un dispositivo móvil. Algunos más destacados son:

- **Extracción manual:** este método consiste en examinar el dispositivo móvil de manera no invasiva moviéndose a través de la pantalla del dispositivo, sin utilizar ninguna herramienta adicional, analizando toda información relevante para la investigación. Es un proceso muy simple, el menos invasivo y aplicable en cualquier dispositivo móvil. Sin embargo, requiere mucho tiempo y puede ser tedioso dado que se deben analizar y documentar todos los archivos que contenga el dispositivo móvil y sacar fotos de cada archivo para su correcta documentación, un aspecto que puede dañar la integridad de la evidencia, ya que el investigador puede modificar o eliminar por error algún contenido del dispositivo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos no invasivos

- **Extracción o adquisición física:** se trata del método más utilizado habitualmente y consiste en la creación de una copia idéntica del original que permite la preservación total de las evidencias potenciales. La extracción física consiste en la recuperación de datos, tanto de la memoria interna del dispositivo como los datos almacenados en la memoria RAM y los datos borrados de los espacios de la memoria no asignados, así como los archivos que se encuentren ocultos. La ventaja principal de este método es la posibilidad de buscar elementos eliminados. Sin embargo, es más complejo que los otros métodos y requiere de una mayor inversión de tiempo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos no invasivos

- **Extracción o adquisición lógica:** este método no invasivo consiste en la realización de una copia de los objetos que estén almacenados en el dispositivo, y para obtenerla, se hace uso de mecanismos que se utilizan habitualmente para sincronizar el dispositivo móvil con un ordenador, es decir, se solicitan los datos al sistema operativo del dispositivo. Se deberá crear una conexión entre el dispositivo móvil y el dispositivo de análisis forense usando una conexión, física o no, con un cable extraíble o USB, conexión *bluetooth*, infrarrojos o un cable RJ-45, es decir, un cable Ethernet. Este proceso es más rápido y compatible con la gran mayoría de herramientas de análisis forense. Sin embargo, no extrae archivos borrados, pero sí archivos que hayan sido etiquetados para su borrado pero aún estén almacenados.

ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos no invasivos

- **Extracción o adquisición del sistema de ficheros:** este último método no invasivo permite recopilar todos los ficheros visibles a través del sistema de ficheros, por lo que no se incluyen aquellos archivos eliminados ni particiones ocultas. Sin embargo, en ocasiones sí es posible recuperar información que, como en el método anterior, está etiquetada para ser borrada pero todavía no ha sido eliminada. Los datos que se recuperen utilizando este método dependerán, en gran medida, del sistema operativo del dispositivo, así como de las herramientas que se utilicen para la extracción de la información, y en función del tipo de investigación que se esté llevando a cabo, este método puede ser suficiente, lo que supone una dificultad menor que la extracción física.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos invasivos

Los métodos invasivos son todos aquellos métodos que pueden interactuar directamente con los componentes internos de un dispositivo móvil. Algunos más destacados son:

- **Método JTAG** (del inglés, *Joint Test Action Group*): el JTAG es un método de comunicación con el dispositivo a través de un chip denominado *Test Access Ports* o TAP. Este método normalmente se utiliza para testear, depurar y verificar el diseño del dispositivo después de su fabricación. En el caso del análisis forense, el JTAG abre una puerta para acceder al dispositivo móvil y extraer los datos de la memoria interna del mismo, así como saltar la seguridad si el dispositivo se encuentra bloqueado.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos invasivos

Sin embargo, no todos los fabricantes dan soporte a esta herramienta y no todos los dispositivos móviles de un mismo fabricante tienen por qué disponer de ella. Por otro lado, todos los datos obtenidos mediante este método estarán sin procesar, así que se deberán tratar manualmente o, por el contrario, si se extraen datos encriptados, estos serán ilegibles, lo que dificultará la utilización de este método con dispositivos iOS que dispongan de *data protection*.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos invasivos

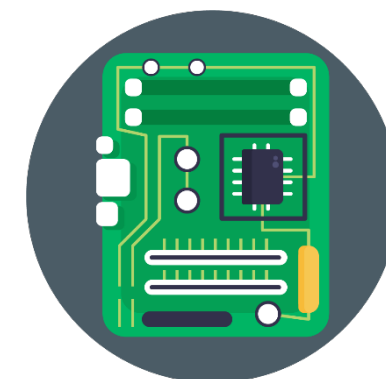
- **Chip Off:** consiste en la extracción del chip de la memoria del dispositivo móvil para su posterior análisis. Este método puede conllevar riesgos, dado que la extracción del chip de la memoria del dispositivo puede ser delicado y cualquier problema que surja durante la extracción puede dañar al chip, produciendo así daños irreversibles en la evidencia y haciéndola inservible en la investigación dado que se rompería la cadena de custodia. Este método se utiliza especialmente en dispositivos móviles, pero también en cualquier dispositivo que utilice memoria *flash* como el GPS, las tabletas, la memoria externa o USB, etc. Para la extracción del chip se deberá identificar la tipología del chip de la memoria del dispositivo, extraer el chip de memoria tomando las precauciones adecuadas y, una vez extraído el chip, se limpiará y se preparará para su correcto análisis.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos invasivos

Una vez extraído el chip, este será introducido en los lectores de chips para poder obtener los datos almacenados y crear así una imagen de los mismos para no romper la cadena de custodia. Finalmente, se deberá proceder al análisis de los datos extraídos con las herramientas destinadas a un análisis forense.

Dado la peligrosidad de este método invasivo, es recomendable utilizar este proceso cuando el dispositivo móvil ha sido completamente dañado pero el chip de la memoria sigue intacto, si se decide preservar y analizar el chip de la memoria del dispositivo por separado o si se han barajado otros métodos de obtención de datos y se recurre a este como última opción.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos invasivos

- **Micro-read:** consiste en el análisis de los circuitos electrónicos del chip de la memoria de un dispositivo móvil, específicamente en la observación de las puertas lógicas NOR o NAND utilizando un microscopio electrónico de alta capacidad para analizar los datos que se puedan observar en el chip. Este método es el más costoso tanto en inversión económica como en tiempo de realización y, además, requiere una alta capacidad técnica.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: métodos invasivos

Las puertas lógicas son bloques en la construcción de un circuito digital y suelen tener un número determinado de entradas y una única salida. Estas entradas están compuestas por código binario que puede ser 0 (falso/apagado) o 1 (verdadero/encendido). De la combinación de las diferentes entradas resultará una salida (*output*) que será un 0 o un 1. Por ejemplo, si un interruptor de luz está encendido significa que hay corriente por lo que el circuito está en 1 y si está apagado, no hay corriente y está en 0. En este sentido, podemos encontrar diferentes puertas lógicas, por lo que la combinación de entradas resultará en una salida diferente. Las puertas lógicas NOR o NAND tienen la siguiente combinación:

NAND		
A	B	Salida
0	0	1
0	1	1
1	0	1
1	1	0

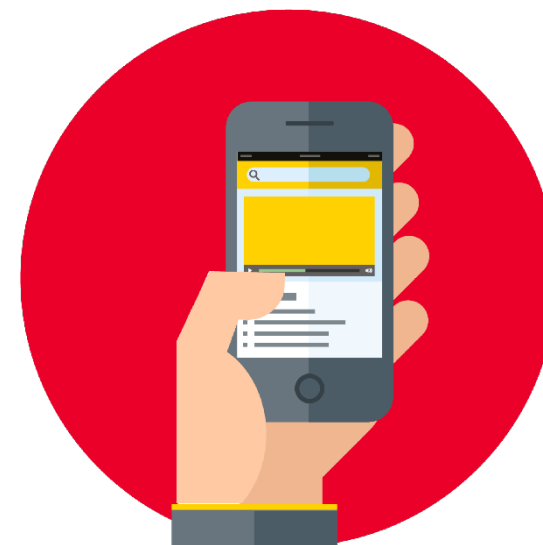
NOR		
A	B	Salida
0	0	1
0	1	0
1	0	0
1	1	0

Fuente: *Micro-read* [Tabla]
Adaptado de
<https://hardzone.es>

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: *jailbreaking*

Jailbreaking es uno de los métodos más utilizados para acceder a los archivos del sistema de dispositivos iOS y ganar acceso al dispositivo. Este *software* explota diferentes vulnerabilidades del sistema operativo para ganar privilegios de superusuario y permitir la extracción de información relevante del dispositivo. Además, trata de aprovechar los defectos de un dispositivo electrónico bloqueado, con el objetivo de instalar un *software* diferente al que el fabricante del dispositivo pone a disposición del mismo. Así permite obtener un acceso total a la raíz del sistema operativo y, por tanto, a todas las funciones de este. Por ejemplo, es el caso de dispositivos iOS a la hora de instalar aplicaciones de terceros y que no se encuentran disponibles en la tienda de aplicaciones App Store.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: *jailbreaking*

Existen numerosas versiones de este *software* que funcionan de manera diferente dependiendo de la versión de iOS sobre la que se ejecute.

¿Sabías qué?

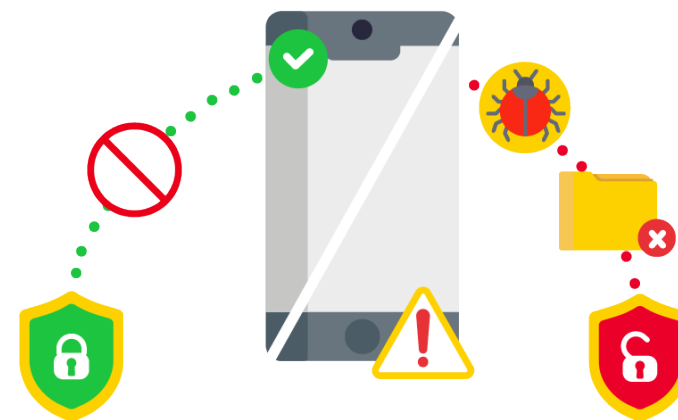
El término *jailbreaking* resulta de la combinación de *jail* (en español, cárcel) y *breaking* (en español, romper), porque implica liberar a los usuarios de la «cárcel» de limitaciones que pueda tener un dispositivo. [\[12\]](#)

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: *jailbreaking*

Los principales inconvenientes de utilizar el método de jailbreaking son:

- **Exponer el dispositivo a Internet:** al exponer el dispositivo a Internet mientras se instala *jailbreak*, se hace susceptible a sufrir algún cambio, como una actualización o sincronización con algún repositorio, lo que podría romper la cadena de custodia provocando que el dispositivo ya no sirviera como posible evidencia. Además, con esta exposición también se permitiría una conexión remota al dispositivo que podría producir un borrado de archivos, cambios en el sistema o que se bloquee el equipo.
- **Fallo en la instalación de *jailbreak*:** al ser un programa que explota vulnerabilidades del sistema operativo para obtener privilegios de acceso al sistema, las ejecuciones de estas vulnerabilidades pueden fallar en cualquier momento.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: *rooting* y ADB

Al igual que el método de *jailbreaking* para dispositivos iOS, el método *rooting* se utiliza para dispositivos Android. Consiste en utilizar diferentes *exploits* del sistema para ganar un acceso privilegiado al sistema operativo del dispositivo, es decir, consigue un acceso *root* o de superusuario. Gracias a este acceso, se podrá crear una imagen del sistema operativo y sustraer los datos del dispositivo, incluidos los datos borrados, para poder analizarlos. El *rooting* de un dispositivo móvil también nos permitirá hacer un análisis de las aplicaciones instaladas en él. Dependiendo de la versión de Android instalada en el dispositivo, se deberá utilizar una herramienta de *rooting* específica.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: *rooting* y ADB

A continuación, podremos utilizar ADB Android Debug Bridge, una herramienta que permite a los usuarios acceder a los archivos internos del sistema del dispositivo mediante comandos para obtener mayor información del dispositivo. Para poder utilizarlo se deberán habilitar previamente las conexiones USB dentro del dispositivo, así como tener el dispositivo móvil en modo rooting dado que para ejecutar los comandos del Android Debug Bridge se necesitan permisos de superusuario.

Para activar el modo depuración de USB se deberán habilitar las opciones de desarrollador dentro de la configuración del dispositivo.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: *rooting* y ADB

El ADB está formada por tres componentes principales:

- **Ciente:** se trata de la interfaz que utilizará el dispositivo que esté conectado al dispositivo móvil para acceder a este y será el encargado de enviar los comandos. Por ejemplo, una consola o una terminal del PC puede facilitar la comunicación con el dispositivo móvil.
- **Daemon (ADB):** hace referencia a un programa que ejecuta los comandos en el dispositivo móvil.
- **Servidor:** este componente se encargará de administrar la comunicación entre el Daemon (ADB) y el cliente.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: memoria externa o USB

Al realizar la extracción de evidencias mediante una memoria externa o USB en dispositivos móviles, se tiene que tener en cuenta que existen dos métodos dependiendo del sistema operativo que esté instalado en el dispositivo:

- **Depuración USB (Android):** como ya hemos mencionado anteriormente, este modo se activa desde las opciones del menú de desarrollador y permite establecer una comunicación desde dispositivos que tengan un *Android Software Developer Kit* (SDK) al dispositivo móvil con Android.
- **Modo restringido (iOS):** se utiliza para dificultar la obtención de datos en caso de pérdida o robo del dispositivo. Si un dispositivo lleva más de una hora bloqueado, este modo impedirá nuevas conexiones mediante una memoria externa USB hasta que se vuelva a desbloquear de nuevo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: herramientas

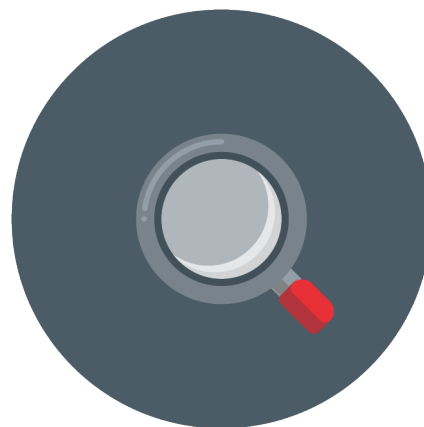
Existen una serie de herramientas tanto *hardware* como *software* para realizar el análisis forense de los dispositivos móviles. A continuación, veremos cuáles son las herramientas o soluciones más comunes:

- **Universal Forensic Extraction Device (UFED):** se trata de una de las herramientas de extracción más famosas y completas del mercado. El UFED es un dispositivo que permite la creación de imágenes de dispositivos móviles y también las analiza para extraer los artefactos. Permite trabajar con más de 6.300 dispositivos móviles distintos, además de ser intuitivo y fácil de usar. Este dispositivo fue creado por la empresa Cellebrite que está especializada en la creación de soluciones forenses. Se trata de una herramienta de pago.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: herramientas

- **Oxygen Forensic Detective:** se trata de una solución para la extracción y análisis de datos de dispositivos móviles. Es una herramienta de pago que permite recopilar información de más de 10.000 modelos de dispositivos móviles e incluso de servicios en la nube.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: herramientas

Además de estas herramientas, en la unidad anterior vimos varias herramientas que también pueden utilizarse para análisis en dispositivos móviles:

- Autopsy.
- CAINE.
- FTK Imager.
- Volatility.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

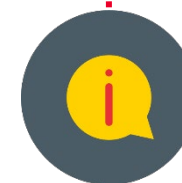
Adquisición de evidencias: Universal Forensic Extraction Device (UFED)

Como hemos mencionado, el dispositivo Universal Forensic Extraction Device (UFED) ofrece a los investigadores forenses la posibilidad de acceder a la información almacenada en un dispositivo móvil, incluso en los casos en los que esté bloqueado por contraseña, patrón o código PIN.

Dicho dispositivo ha avanzado mucho en los últimos años y, actualmente, cuenta incluso con una pantalla táctil que hace que su funcionamiento sea muy sencillo e intuitivo para cualquier investigador que necesite usarlo.

¿Sabías qué?

Este dispositivo es utilizado por la policía de 100 países en todo el mundo y ha servido en más de 40.000 investigaciones.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: Universal Forensic Extraction Device (UFED)

Algunos de los datos que puede conseguir este dispositivo son los siguientes:

- Registro de llamadas.
- Lista de contactos.
- Fotografías y vídeos.
- Archivos de sonido.
- IMEI (del inglés, *International Mobile Equipment Identity* o identidad internacional de equipo móvil) del teléfono: identificador único de cada dispositivo a nivel mundial.
- Número de teléfono.
- ICCID (del inglés, *Integrated Circuit Card Identifier* o identificador de la tarjeta del circuito integrado) e IMSI (del inglés, *International Mobile Subscriber Identity* o identidad internacional del abonado móvil).
- Información de localización.
- Geoetiquetas gráficas en Google Maps.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: Oxygen Forensics Detective

La herramienta Detective, de Oxygen Forensics, también resulta muy útil para la extracción de evidencias de dispositivos móviles. Asimismo, permite la extracción de múltiples fuentes como:

- Los dispositivos móviles e IoT.
- Las copias de seguridad.
- Las tarjetas de memoria.
- El almacenamiento en la nube.
- UICC (del inglés, *Universal Integrated Circuit Card* o tarjeta de circuito integrado universal) es una tarjeta con un procesador, memoria no volátil, memoria ROM y memoria RAM. Además, tiene un identificador único para cada dispositivo de una red de telefonía móvil.

Dicha herramienta se distribuye en un dispositivo USB para su utilización por un único usuario y evitar copias no autorizadas.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: Obtención de datos de la memoria

Dado que existen diferentes tipos de tarjetas de memoria, el investigador forense necesitará un tipo de adaptador diferente para poder analizar cada una de ellas, como adaptadores SD, microSD o miniSD, entre otros.

El proceso de extracción dependerá tanto de la tarjeta de memoria como de qué sistema operativo tenga el dispositivo. Por ejemplo, en los sistemas Android no se almacena información del sistema en la memoria, solo se almacenan los datos que genera el usuario, como los archivos multimedia, fotos, mensajes, etc.

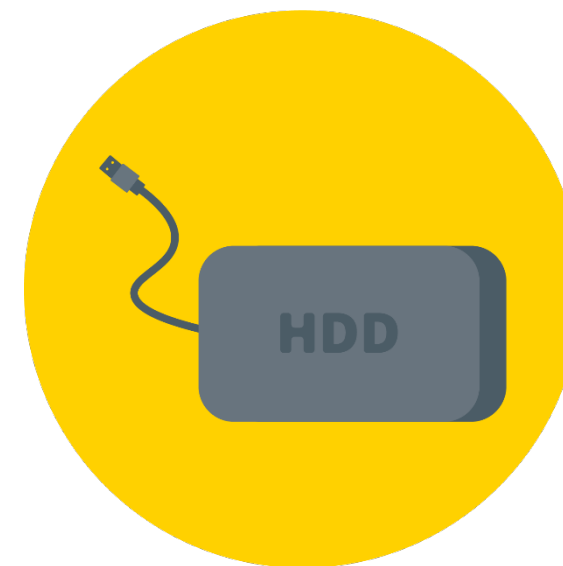


Fuente: *Ejemplo de adaptador de tarjetas* [Captura de pantalla]
Extraído de <https://www.ebay.es>

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: Obtención de datos de la memoria

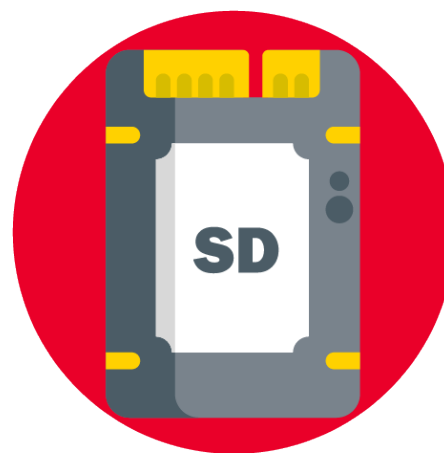
Para adquirir datos o evidencias de una tarjeta SD se sigue un proceso similar al análisis de un disco duro. En primer lugar, se extrae la tarjeta de memoria del dispositivo y se conecta la tarjeta al equipo de trabajo como «solo lectura». Para ello, se debe deshabilitar la escritura previamente y así evitar que las evidencias sufran alguna modificación y mantener la integridad de la evidencia. A continuación, se realiza un clonado de la tarjeta de memoria utilizando alguna de las herramientas anteriores y calculamos el *hash* de la muestra. Una vez hecho el clonado de la tarjeta, se analiza la imagen de la memoria con las herramientas adecuadas, como Autopsy o FTK Imager.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: clonado de la memoria interna

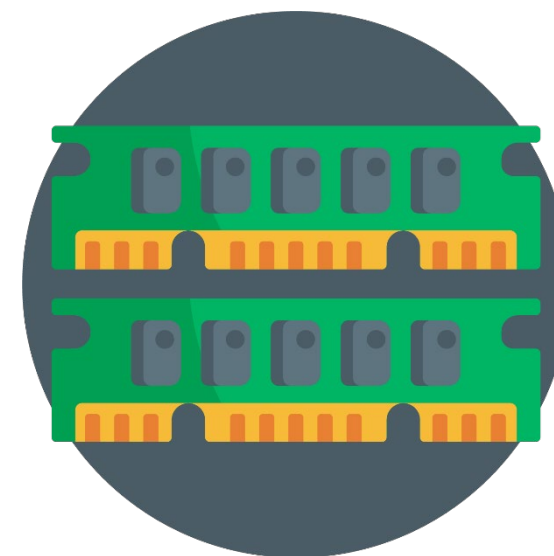
Para el volcado de memoria RAM utilizaremos la herramienta LiME, una herramienta *open source* para la adquisición de evidencias volátiles de sistemas Linux o sistemas basados en él, como por ejemplo, el sistema Android. LiME se caracteriza por permitir el volcado de memoria RAM directamente a la tarjeta SD a través de ADBD y por minimizar su interacción entre el usuario y los procesos del Kernel, lo que le permite generar capturas de memoria más sólidas desde el punto de vista de una investigación forense.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: clonado de la memoria interna

Tras realizar el volcado de memoria RAM se procederá a la copia física de la memoria interna del dispositivo se deberá realizar sobre el *hardware* y *software* del dispositivo. Así, para la clonación *hardware* se utilizará la Cellebrite UFED, mientras que para la clonación *software* se podrá utilizar el método manual de instalación de SDK de Android en el equipo, *rootear* el sistema Android y clonar las particiones con el comando `.dd` (*Dataset Definition*). Por otro lado, la clonación *software* también se utiliza como herramienta específica para el clonado directo de la memoria de un dispositivo Android.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: adquisición de la imagen física de la memoria interna

Para la adquisición de la imagen física de la memoria interna se utilizará SDK (*Software Development Kit*), ya que facilitará el acceso al dispositivo.

Un SDK es un conjunto de herramientas a disposición de los usuarios que, normalmente, es ofrecida por el fabricante de un determinado *hardware*, de un sistema operativo o de un lenguaje de programación.

En el caso del SDK de un dispositivo móvil, este proporcionará al analista forense una vía de acceso al dispositivo. De esta manera, solo se tendrá que instalar el SDK en el dispositivo a analizar y, una vez que se haya conectado el dispositivo móvil a través de una memoria externa USB al dispositivo de análisis forense, se podrá interactuar con él. Así, el analista forense podrá consultar la información almacenada en el dispositivo y extraer los datos del mismo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: datos de la red telefónica

Los dispositivos móviles siempre van acompañados de un servicio de telefonía que les permite realizar todas las comunicaciones. Las conexiones principales de comunicación que dependen del proveedor de telefonía son:

- **Las llamadas telefónicas:** las llamadas telefónicas tradicionales se realizan a través de la red móvil a la cual se accede gracias al operador.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: datos de la red telefónica

- **Datos móviles:** estos permiten a los usuarios disponer de conexión a Internet sin necesidad de una red wifi. Mediante esta conexión se establecen una cantidad de servicios *Over The Top* (OTT), que son servicios de libre transmisión, es decir, plataformas que emiten contenido a través de Internet sin necesidad de recurrir a los operadores telefónicos para difundirlo. Los usuarios, para conectarse, simplemente necesitarían un dispositivo con conexión a Internet. Algunos ejemplos de servicios OTT son aplicaciones de visualización de series y películas, aplicaciones de música y aplicaciones de videollamada.
- **SMS:** el servicio de mensajería clásico también utiliza la red de telefonía para llevar a cabo todos sus servicios.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: datos de la red telefónica

Debido a la cantidad de servicios que se realizan a través de los operadores de telefonía móvil, es importante conocer algunos de sus elementos más importantes:

- ***Subscriber Identity Module (SIM)***: como hemos visto, la tarjeta SIM contiene información sensible para dotar a los dispositivos de comunicación con la red móvil. Esta tarjeta consta de los siguientes elementos, algunos ya los hemos comentado:
 - ***Integrated Circuit Card Identifier (ICCID)***.
 - ***International Mobile Subscriber Identity (IMSI)***.
 - ***Last Dialed Numbers (LDN)***: permite ver los últimos números marcados.
 - ***Service Provider Name (SPN)***: se trata del nombre del proveedor de servicios de telefonía.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: datos de la red telefónica

- **Mobile Switching Center (MSC) o centro de conmutación móvil:** hace referencia a una central telefónica que realiza la conmutación o conexión necesaria para establecer las comunicaciones.
- **Base Transceiver Station (BTS) o estación base:** es la estación a la que se conectan los dispositivos de los usuarios finales y gracias a las cuales dichos usuarios disponen de acceso a la red de telefonía en cualquier lugar.
- **Base Station Controller (BSC) o controlador de la estación base:** es la estación que se encarga de la gestión de varias BTS y de todo lo relacionado con la asignación de frecuencias y canales.
- **Base Station Subsystem (BSS) o subsistema de estación base:** es la estación encargada de gestionar las BTS, las BSC y todo el tráfico que fluye por ellas.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: datos de la red telefónica

- **Home Location Register (HLR) o registro de ubicación base:** se trata de una base de datos que contiene información sobre todos los usuarios de la red de telefonía, como la posición del usuario en la red, si se encuentra conectado o no, qué servicios puede o no utilizar, etc.
- **Visitor Location Register (VLR) o registro de ubicación de usuarios:** es una base de datos que almacena los usuarios activos en ese momento en esa parte de la red.
- **Authentication Center (AuC) o centro de autenticación:** este centro almacena información, como el IMSI y las claves de autenticación del usuario.
- **Equipment Identity Register (EIR) o registro de la identidad de equipo:** es una base de datos que contiene información de dispositivos móviles junto a su IMEI.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM

El análisis forense de la tarjeta SIM es una fase indispensable del proceso de análisis forense de un dispositivo móvil. Esta tarjeta puede contener algunos de los datos importantes que podrán ayudar al investigador a descubrir las razones que han ocasionado la incidencia.

El proceso de la extracción de la información de la tarjeta SIM seguirá los siguientes pasos:

- **Retirar** la tarjeta SIM del dispositivo que se esté analizando.
- **Crear** una imagen de la tarjeta SIM para su análisis.
- **Preservar** la tarjeta SIM de manera adecuada.
- **Extraer** los datos de la tarjeta SIM clonada para su análisis.
- **Analizar** los datos que se obtengan.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM

Para el análisis forense de una tarjeta SIM será necesario emplear algunas herramientas de clonado y gestión de información. Algunos ejemplos son el clonador o lector de tarjetas SIM (XACT), MOBILedit!, SIM Manager y SIMSpy.

Al clonar una tarjeta SIM se obtendrá una copia exacta con el mismo IMSI y KI de la tarjeta original, con los que se puede identificar y autenticar la tarjeta de red. Este proceso difiere del clonado que realizan los operadores donde sí se renuevan estos valores.

El HW de clonado XRY permite clonar una SIM sin el código PIN generando una nueva tarjeta SIM con toda la información disponible. Para ello, se requieren dos elementos:

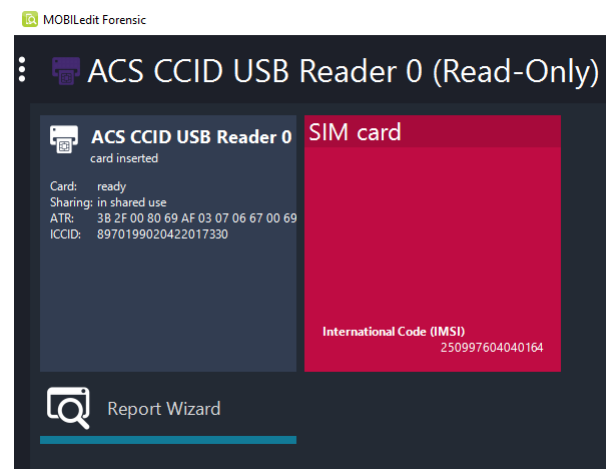
- **ICCID o *Integrated Circuit Card Identity***
- **IMSI o *Internacional Mobile Subscriber Identity***

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM: ICCID

Para el análisis de la clave ICCID y del IMSI se recomienda utilizar la aplicación MOBILedit!, que permitirá recuperar los datos del país de origen y la entidad que ha expedido la tarjeta SIM.

Fuente: *ICCID* [Captura de pantalla] Extraído de <https://www.mobiledit.com>

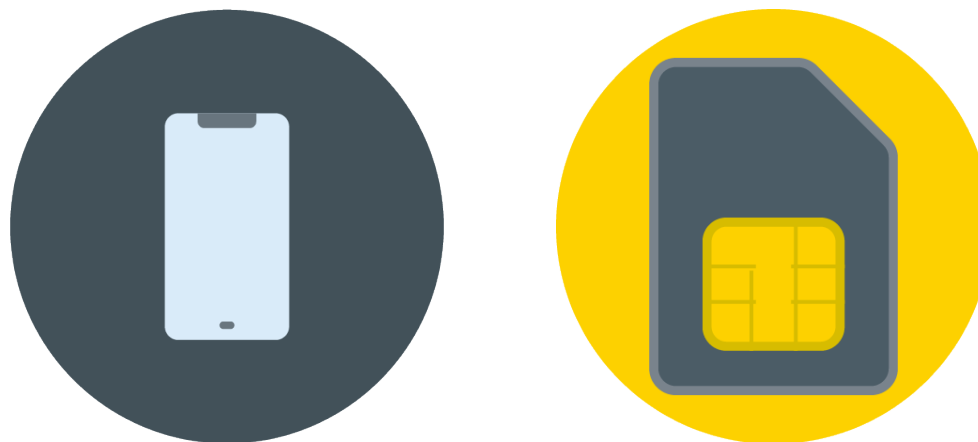


Fuente: *ICCID* [Captura de pantalla] Extraído de <https://subscription.packtpub.com>

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM: MOBILedit!

MOBILedit! es un *software* de pago de análisis de dispositivos móviles que permitirá extraer información tanto de un dispositivo móvil como de la tarjeta SIM. Esta información será convertida en informes que reflejarán los datos que se han extraído.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM: MOBILedit!

Veamos cómo se realizaría análisis del IMSI con MOBILedit!:

- Para recuperar el país de origen y el operador de red asociado a la tarjeta, se escogen las 6 primeras cifras del número y se comparan con las definidas por ITU-T en su documento [\[13\]](#).
- Se extraen los contactos almacenados en la tarjeta SIM del dispositivo. Los contactos que estén alojados en la memoria del teléfono o en la nube no podrán ser extraídos.
- Se podrá obtener el listado de llamadas que se han realizado desde el teléfono móvil y adquirir la siguiente información: el número de teléfono de destino, la fecha y hora de las llamadas y la duración de las llamadas.
- Por último, se podrá conseguir un listado de SMS/MMS o de las aplicaciones de mensajería instantánea con la siguiente información: número de teléfono de origen y destino, comprobación de lectura, el contenido de los mensajes y la fecha y hora de envío del mensaje.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM: SIM Manager

También se pueden recuperar los SMS eliminados que se encuentren dentro de la tarjeta SIM, gracias a la herramienta gratuita SIM Manager, ya que, al igual que con la papelera de reciclaje en los equipos Windows, cuando se borra un archivo este no está completamente borrado hasta que no se haya sustituido el espacio que ocupaba con un nuevo archivo. En el caso de la tarjeta SIM, el estado de la celda donde se almacenaba el mensaje cambia de estado «en uso» a «vacío». Dependiendo de la tarjeta, se pueden recuperar entre 20 y 25 mensajes eliminados.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM: LAI

Por otro lado, también se puede obtener la información de la ubicación en la que se ha encontrado el dispositivo gracias al identificador LAI, que se encuentra almacenado en la tarjeta SIM.

LAI (del inglés, *Location Area Identity*) se utiliza en las redes de operadores que se dividen en áreas locales y cada una de estas áreas posee una LAI única. Al cambiar de ubicación, el dispositivo registra el LAI de la zona y la envía al operador. Al apagar el teléfono y volver a encenderlo, este recupera el LAI anterior.

El LAI está compuesto por 11 dígitos que se dividen de la siguiente forma para proporcionar la información:

- Código de país (MCC) (3 dígitos): identifica al país. Por ejemplo, España es 214.
- Código de operador de red (MNC) (2-3 dígitos): identifica al operador de red.
- Código de área de localización (LAC) (5 dígitos): identifica la zona de ubicación.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias: obtención de datos de la memoria SIM: SIMCon

Otra herramienta de pago que resulta muy útil para realizar la extracción de información de una tarjeta SIM es SIMCon. Este programa permite analizar los datos de una tarjeta SIM e incluso acceder a datos que pueden estar protegidos por contraseña. Para realizar el análisis de una tarjeta SIM con esta herramienta se tienen que seguir estos pasos:

1. Una vez instalado el programa en el equipo de análisis forense, este se conectará al lector de tarjetas SIM en el que se introducirá la tarjeta a analizar.
2. Abrir el programa de SIMCon, que detectará la tarjeta SIM y solicitará introducir el código PIN de la tarjeta SIM.
3. Iniciar el proceso de extracción de datos de la tarjeta.
4. Tras concluir el proceso de análisis el programa, rellenar el formulario del investigador y proceder a analizar los datos extraídos.
5. A diferencia de la herramienta MOBILedit!, SIMCon permite ver la información extraída y no solo generar un informe final de esa información.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: OWASP

Como hemos visto, para poder llevar a cabo un análisis forense en un dispositivo móvil es importante conocer cuáles son las principales vulnerabilidades asociadas a los mismos.

Una de las fuentes más fiables relacionada con riesgos en dichos dispositivos es la plataforma OWASP, que define un top 10 de vulnerabilidades que veremos con más detalle a continuación. Se trata de una lista de las diez principales vulnerabilidades móviles, realizada en 2016, por lo que algunas de estas vulnerabilidades ya han sido solventadas, en cuyo caso, se podrá encontrar información sobre el parche que se debe aplicar para solventarla.

En este enlace [\[14\]](#) puedes acceder al listado del top 10 riesgos móviles OWASP.



Fuente: *Logo OWASP* [Logo] Extraído de <https://www.blackmantisecurity.com>

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: uso inadecuado de plataforma

Esta amenaza hace referencia a las aplicaciones o características de dispositivos móviles que no hacen un buen uso de los controles de seguridad del sistema, es decir, aplicaciones que no utilizan correctamente los recursos de seguridad del sistema operativo. Por ejemplo, que una aplicación de edición de fotos solicite permisos de acceso a la lista de contactos.

Mitigaciones:

- Restringir la comunicación entre aplicaciones, limitar el acceso, implementar permisos restrictivos para archivos, etc.
- Aplicar todos los controles posibles en las implementaciones de Android y iOS.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: almacenamiento inseguro de datos

En el caso de que un teléfono móvil se pierda o sea infectado por *malware*, es posible que alguien o el *malware* trate de acceder a los datos personales del usuario. Por eso, los datos del dispositivo deben ser almacenados de forma segura para evitar este tipo de incidentes. Por ejemplo, no se deberían crear notas de texto con las contraseñas, ya que, si el dispositivo se pierde o es robado, todas esas contraseñas quedarían expuestas.

Mitigaciones:

- Garantizar que los datos estén cifrados con algoritmos de cifrado robustos y llevar una buena gestión de las claves utilizadas.
- Almacenar únicamente la información que se considere necesaria, evitando así la exposición innecesaria de los datos o información sensibles.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: comunicaciones no seguras

Dado el continuo uso que se realiza de los dispositivos móviles y su permanente conexión a Internet, es importante garantizar que las comunicaciones también se realicen de forma segura. En caso contrario, un atacante puede utilizar estas vulnerabilidades para comprometer los dispositivos y sus datos. Por ejemplo, navegar por páginas web que no disponen de certificados de seguridad puede facilitar el acceso no autorizado al dispositivo y sus datos.

Mitigaciones:

- En caso de ser el propietario de un sitio web: utilizar certificados SSL/TLS de Autoridades de Certificación (AC) conocidas por asegurar los canales de comunicación.
- En caso de ser un usuario: evitar acceder a páginas que no tengan un certificado SSL/TLS, es decir, que no sean HTTPS.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: autenticación no segura

Gran parte de los incidentes de seguridad relacionados con dispositivos móviles tienen su origen en los métodos de autenticación no seguros. Así, en caso de que un atacante consiga saltarse esta autenticación tendrá acceso a muchas de las funciones del dispositivo. Por ejemplo, muchos usuarios disponen de una aplicación de su banco para poder acceder a la información de su cuenta bancaria y realizar diferentes acciones. Si no se dispone de un método de autenticación seguro, un atacante podría llegar a acceder a esa cuenta y a los datos que contiene.

Mitigaciones:

- Evitar los métodos de autenticación local, dejando esta responsabilidad en la parte del servidor para tener mayor seguridad.
- Evitar métodos de autenticación no seguros, no guardar las contraseñas localmente, implementar autenticación multifactor, evitar los códigos numéricos de cuatro dígitos, etc.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: criptografía insuficiente

El uso de algoritmos criptográficos de baja seguridad puede perjudicar gravemente la seguridad de los dispositivos móviles. Este método poco seguro puede permitir a los atacantes acceder a los datos personales e incluso a datos de autenticación en diferentes sitios web.

Mitigaciones:

- Aplicar algoritmos criptográficos robustos, tal y como indica el National Institute of Standards and Technology (NIST), que puedes consultar aquí [\[15\]](#).
- Evitar almacenar información sensible en el dispositivo móvil, siempre que sea posible, para evitar así el compromiso de dichos datos.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: autorización insegura

Además de la autenticación, es importante gestionar correctamente el proceso de autorización, en el cual se comprueba si determinado usuario tiene los permisos necesarios para realizar una determinada acción en el dispositivo, ya que, en caso contrario, un atacante podría iniciar sesión como si fuera el usuario legítimo. Por ejemplo, si se trata de un usuario genérico, este no debería disponer de permisos de administrador.

Mitigaciones:

- Asegurar la ejecución del proceso de autorización de manera correcta en cada una de las peticiones que se realicen.
- Validar correctamente los permisos de los usuarios autenticados. En este punto es importante asegurar que cada usuario tenga únicamente los permisos necesarios.

ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: calidad del código cliente

La baja seguridad en las aplicaciones descargadas en un dispositivo puede permitir a un atacante la posibilidad de utilizar su código de forma maliciosa para comprometer el dispositivo y la información almacenada en él. Por ejemplo, un atacante podría ejecutar código dentro de la aplicación y provocar un desbordamiento del rendimiento o un uso excesivo de memoria.

Mitigaciones:

- Utilizar herramientas automatizadas que realicen pruebas sobre las aplicaciones para comprobar si existen estas vulnerabilidades.
- Utilizar patrones seguros de programación en todos los departamentos de la organización.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: manipulación de código

Algunas aplicaciones, sobre todo aquellas que se descargan directamente de sitios no oficiales, simulan el comportamiento de las aplicaciones oficiales, pero tienen incrustado código malicioso utilizado por los atacantes para conseguir acceso a los dispositivos móviles. Por ejemplo, si un atacante desarrolla una versión falsificada de una aplicación e instala código malicioso en ella, podría robar los datos confidenciales de los usuarios que hayan descargado y utilizado esa versión falsa.

Mitigaciones:

- Las aplicaciones deben estar preparadas para identificar cualquier tipo de cambio en su propio código, evitando así dicha manipulación.
- Descargar las aplicaciones de sitios oficiales, comprobar si están firmadas, comprobar el *hash* de la aplicación, etc.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: ingeniería inversa

Muchos ataques en dispositivos móviles tienen su origen en la capacidad que un ciberdelincuente tiene de realizar ingeniería inversa sobre las aplicaciones para así entender su código y poder utilizar este conocimiento para comprometer el sistema. Algunas aplicaciones, como IDA Pro o Hopper, permiten analizar el código y modificarlo posteriormente. Por ejemplo, como hemos visto, Android tiene un sistema operativo *open source*, por lo que el atacante podría descargar el código de una aplicación, descifrarlo, analizarlo y modificarlo.

Mitigaciones:

- Desarrollar el código fuente correctamente para que no exista la posibilidad de deshacer el proceso de cifrado. De esta forma, las herramientas de ingeniería inversa no serían suficientes para comprometer el dispositivo.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Principales riesgos de las aplicaciones: funciones no deseadas

En muchas ocasiones, los desarrolladores cometen errores de programación en el código fuente que permiten la ejecución de determinadas funcionalidades no deseadas en las aplicaciones que pueden ser utilizadas por los atacantes para comprometer el sistema.

Mitigaciones:

- Comprobar correctamente todas las opciones de configuración y verificar que ninguna de ellas está activada por error o es sospechosa.
- Asegurar que los ficheros de *logs* de la aplicación no almacenan información descriptiva acerca del desarrollo *backend* que pueda ser utilizada por un atacante.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: métodos

Dado que una de las potenciales amenazas a las que se puede enfrentar un dispositivo móvil es la descarga o instalación de aplicaciones maliciosas, se hace indispensable conocer por parte de los analistas forenses cómo realizar un análisis de una aplicación en un dispositivo.

Cada día se desarrollan y surgen nuevas aplicaciones en el mercado, por lo que el riesgo de que un usuario se descargue una aplicación potencialmente maliciosa o no legítima es muy alto. Por ello, a continuación veremos qué método se debe llevar a cabo para realizar el análisis de aplicaciones tanto en sistemas Android como en iOS. Además, se debe tener en cuenta que en ocasiones se requerirá escalar derechos para poder extraer la información, por lo que se utilizará el método de *jailbreaking* que ya hemos visto.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: Android

Para poder realizar el análisis de una aplicación de Android, primero se debe comprender cómo está estructurada una aplicación en este sistema operativo. Una aplicación de Android tiene siempre el formato APK (abreviatura de *Android Application Package*), que suele contener los siguientes archivos:

- **Res:** se trata de una carpeta que contiene los recursos necesarios para el funcionamiento de la aplicación.
- **Asset:** es un fichero que contiene los elementos adicionales para la aplicación.
- **Lib:** hace referencia a las bibliotecas adicionales para el funcionamiento de una aplicación.
- **META-INF:** esta carpeta contiene la información y los metadatos necesarios para que la aplicación pueda funcionar correctamente, por ejemplo, cuál es la clase principal de la aplicación, quién es su autor o desarrollador, etc.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: Android

- **AndroidManifest.xml**: contiene información esencial acerca de la aplicación, como los requisitos del *hardware* necesarios para el funcionamiento de la aplicación o los permisos que requiere para su ejecución.
- **Classes.dex**: este archivo es el ejecutable que contiene la gran mayoría del código de la aplicación.
- **Resources.arsc**: esta carpeta contiene recursos pre-compilados de la aplicación que se suelen utilizar para mejorar el funcionamiento de la misma.



Fuente: *Estructura de aplicaciones Android* [Gráfico] Adaptado de <https://www.researchgate.net>

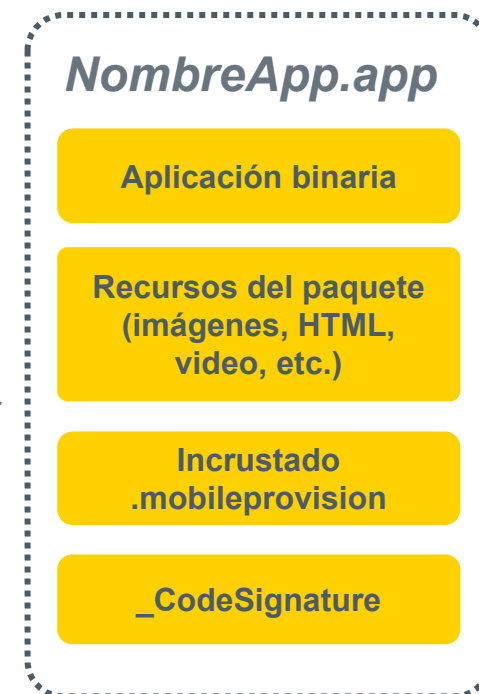
3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: iOS

A diferencia de los dispositivos Android, las aplicaciones en iOS se encuentran en el entorno cerrado de Apple, lo cual aumenta su seguridad. Pero aún así, las aplicaciones pueden distribuirse de forma maliciosa o replicar dando lugar a aplicaciones no legítimas.

La estructura de ficheros de una aplicación en iOS se presenta en el formato IPA (iOS App Store Package), cuyos elementos son:

- **App binary:** se trata del ejecutable que contiene todo el código de la aplicación compilado.
- **Info.plist:** contiene información general de la aplicación, como el nombre de la aplicación o la versión de la misma.
- **Frameworks:** almacena un listado de las bibliotecas que requiere la aplicación para poder funcionar.
- **Embedded.mobileprovision:** este fichero contiene el certificado que requiere la aplicación para funcionar en iOS.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: iOS

Existen numerosas aplicaciones específicas para el análisis de archivos IPA, siendo algunas de las más utilizadas:

- **Pslistutil:** se trata de una herramienta de línea de comandos que permite analizar el fichero plist.
- **Otool:** esta herramienta se utiliza para desensamblar el binario de la aplicación. Puede ser útil para conocer las API que utiliza una aplicación o las clases y métodos que esta tiene implementados.
- **Jtool:** se trata de una herramienta de línea de comandos que mejora la funcionalidad de Otool.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

Tras conocer la estructura de una aplicación Android y iOS, vamos a entender los resultados que se obtienen de un análisis de una de estas aplicaciones. Existen muchas herramientas para el análisis de aplicaciones, pero uno de los entornos de trabajo o *frameworks* más utilizados es MobSF [\[16\]](#).

Mobile Security Framework (MobSF) es una aplicación *open source*, disponible en Linux, MacOS y Windows, que permite realizar el análisis automatizado de aplicaciones Android y iOS. Tiene la capacidad de realizar el análisis, tanto de forma estática como dinámica, de los archivos binarios de la aplicación. Una de las características más interesantes es que genera un informe muy completo con los resultados del análisis.



Fuente: *Logo MobSF* [Logo] Extraído de <https://github.com>

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

Para el análisis de una APK con MobSF, introduciremos el fichero en la aplicación y esta realizará el análisis por sí misma. Una vez completado el proceso, MobSF mostrará los resultados que haya obtenido y proporcionará la opción de exportarlo o imprimirlo como un documento PDF.

En el caso de que un análisis no sea concluyente, se recomienda contrastar el resultado obtenido con el de otras herramientas.

Para este ejemplo realizaremos el análisis sobre una aplicación llamada Currency Converter Plus.



Android Currency Converter Plus (1.5)

Fuente: *MobSF*

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

En la parte superior del informe de los resultados se muestra un resumen con alguno de los puntos más destacables del análisis:

- **Average CVSS:** hace referencia a la puntuación relacionada con las vulnerabilidades que presenta la aplicación; su valor está comprendido entre 0 y 10.
- **Security Score:** se trata de la puntuación asociada al riesgo. Cuanto menor sea el número, menor riesgo de que la aplicación dañe nuestro dispositivo. Una puntuación de 10 significa que existe un riesgo elevado de que sea una aplicación maliciosa.
- **Package Name:** es el nombre del paquete de la aplicación, que puede ser contrastado con fuentes oficiales para comprobar si se trata de una aplicación legítima.

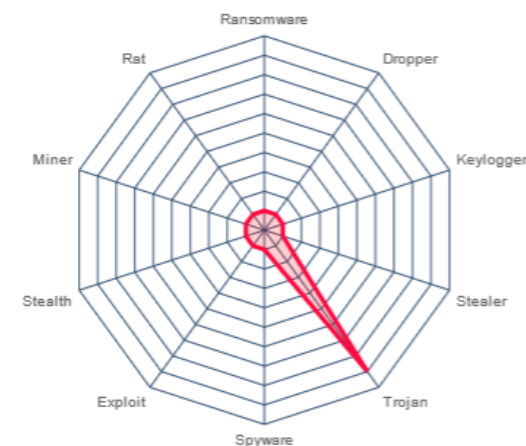
3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

Comparar el resultado de análisis de esta aplicación con otra herramienta puede dar lugar a otra perspectiva y aportar más evidencias para la investigación forense. A continuación, se muestra el resultado obtenido al analizarlo en una SandBox, que clasifica la aplicación como un troyano.



Classification



Fuente: Cuckoo

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

Algunas de las firmas de más riesgo que se han notificado durante el análisis son las siguientes:

- La aplicación solicita permisos que son de riesgo.
- La muestra es detectada por 15 motores de AV (antivirus) de VirusTotal.
- La aplicación se detecta como maliciosa por fuentes de inteligencia, como son Maltiverse o MalwareBazaar.
- La aplicación posee mecanismos para detectar su emulación en entornos de análisis.

⊗ Application Asks For Dangerous Permissions (Static) (7 events)

⊗ Application Contains Secondary DEX File (Static) (2 events)

⊗ Generates some ICMP traffic (1 event)

⊗ Communicates with host for which no DNS query was performed (1 event)

⊗ Application Using Emulation Detection (Static) (9 events)

Fuente: *Cuckoo*

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

Muchas veces también se puede observar que la aplicación está firmada. Sin embargo, al buscar por el nombre del paquete en la tienda de aplicaciones de Google Play, aparece una aplicación totalmente distinta a la original, lo cual nos puede indicar de que se trata de una aplicación maliciosa.



Fuente: *ModSF*

com.iqiyi.i18n
com.iqiyi.i18n.p05f9560f
1.5
1
28
24
None
Scheme V1 (JAR) Scheme V2 (APK) Scheme V3 (APK)
View original

Fuente: *Google Play*

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Adquisición de evidencias de las aplicaciones: ejemplo de análisis

Además, se recomienda revisar en los resultados del análisis los permisos que requiere la aplicación, lo que puede dar un indicio de que la aplicación es maliciosa si requiere de permisos de riesgo que no tendría por qué requerir para su funcionamiento normal. Algunos de los permisos más habituales son:

Permiso de riesgo	Descripción
READ_PHONE_STATE	Acceso a las características del dispositivo de las llamadas activas; determinar el número de teléfono, número de serie, etc.
CALL_PHONE	Permite que la aplicación inicie una llamada telefónica.
READ_CONTACTS	Permite a la aplicación leer todos los contactos almacenados en el teléfono. Esta información podría ser exfiltrada a un tercero.
READ_SMS SEND_SMS WRITE_SMS	Permite a la aplicación escribir y enviar SMS, así como leer o borrar SMS existentes en el teléfono o tarjeta SIM.
INTERNET	Permite que la aplicación cree sockets/conexiones de red.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Documentación: informe final

La redacción del informe final se realizará de forma similar a un informe forense de un dispositivo no móvil. Como hemos visto en unidades anteriores, existen varias metodologías y normas para crear el documento, incluso algunas personalizadas por cada organización.



3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

Documentación: informe final

Sin embargo el informe deberá cumplir una serie de aspectos:

- **Asunto:** hace referencia al objeto del informe.
- **Análisis:** se indican las evidencias que se han recogido, así como las pruebas que se van a realizar sobre las mismas y la finalidad que se pretende conseguir con su realización. Además, se recoge la documentación de las pruebas realizadas y su seguimiento paso a paso, junto con la cadena de custodia de cada una de las evidencias.
- **Conclusiones:** hace referencia a la proposición final del informe en base al análisis realizado previamente.

3 ANÁLISIS FORENSE EN DISPOSITIVOS MÓVILES

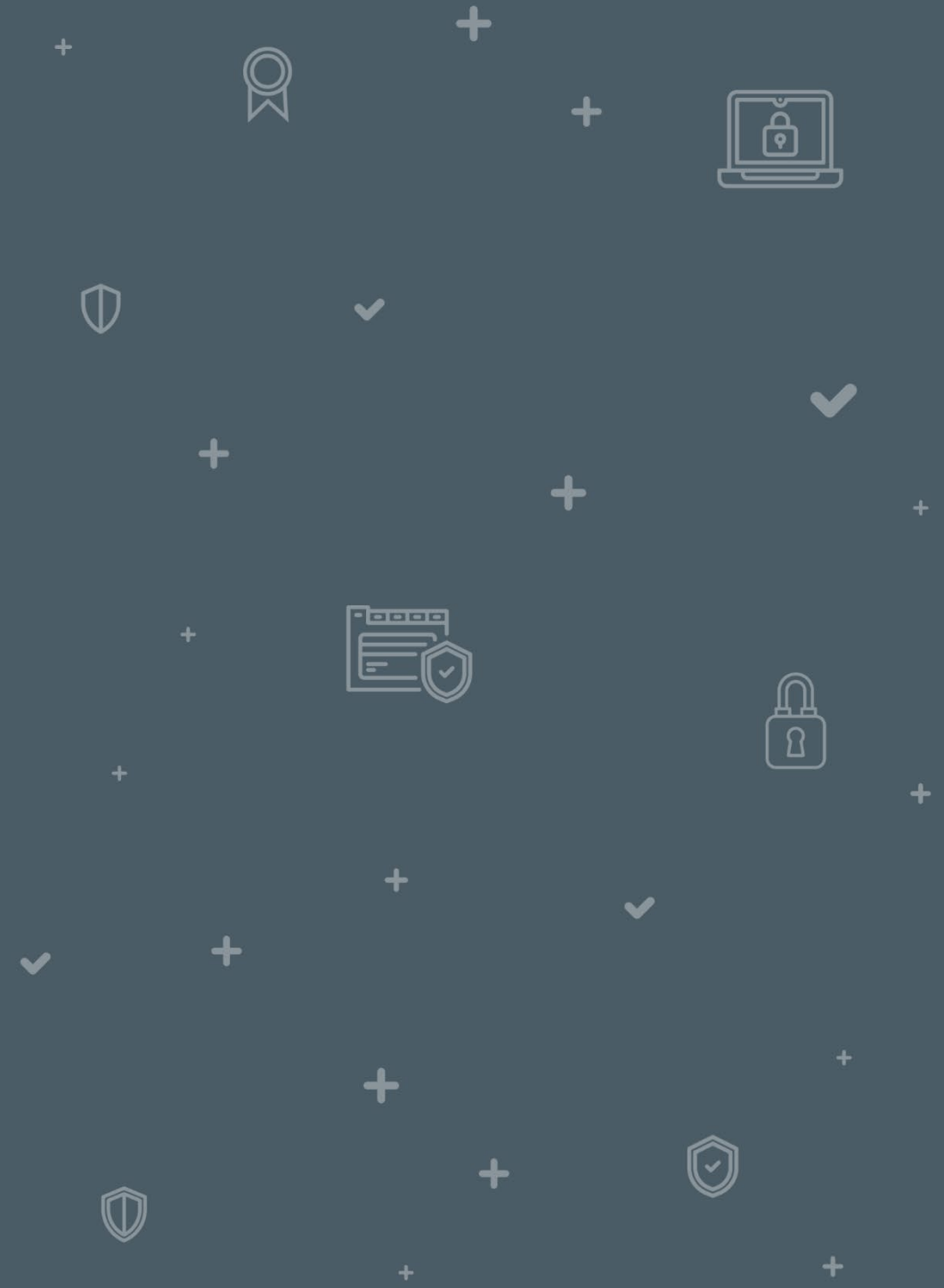
Documentación: informe final

Recordamos que existen dos tipos de informes finales:

- **El informe detallado**, que contiene todas las actividades y tareas que se han llevado a cabo en la investigación, el método y procedimientos seguidos para obtener la información, así como los resultados obtenidos de las evidencias encontradas.
- **El informe ejecutivo** presenta un resumen de alto nivel de los resultados obtenidos en el análisis forense y se distribuye entre los responsables de la investigación. Este informe se complementa con el informe detallado con el objetivo de validar los resultados por parte de los ejecutivos si fuera conveniente.

4

BUENAS PRÁCTICAS



4 BUENAS PRÁCTICAS

Buenas prácticas

Dada la naturaleza volátil de las evidencias que podremos encontrar dentro de los dispositivos móviles, un investigador forense deberá tener especial cuidado a la hora de tratar con estos dispositivos. A continuación, se detallan algunas de las prácticas correctas que se deberán tener en cuenta a la hora de realizar un proceso de análisis forense:

- Tratar correctamente las evidencias para así mantener la cadena de custodia intacta.
- Mantener el dispositivo móvil aislado de cualquier red.
- Conectar el dispositivo móvil a la red eléctrica para evitar que se apague durante toda la investigación.
- Mantener las tarjetas propias del dispositivo conectadas a él hasta llegar al laboratorio para su posterior análisis.
- Anotar toda la información acerca del estado actual del dispositivo a la hora de su recogida.
- No contaminar las evidencias de un dispositivo objetivo con las evidencias recogidas de otros dispositivos.
- Documentar los métodos que se vayan a utilizar para obtener los datos del dispositivo móvil.

4 BUENAS PRÁCTICAS

Buenas prácticas

- Una vez extraídas las evidencias volátiles del dispositivo y que este haya llegado al laboratorio para su análisis, retirar las tarjetas propias del dispositivo para su posterior análisis individual.
- Realizar varias copias de la memoria del dispositivo móvil para asegurar la integridad de las evidencias.
- Comprobar que los datos extraídos del dispositivo móvil han sido correctamente extraídos comparándolos con los del dispositivo original.
- El documento de manejo de evidencias deberá contar con una copia de la autorización para la realización de la investigación forense, documentación que detalle cómo se está realizando cadena de custodia y fotos de cómo se ha realizado el empaquetamiento de las evidencias.
- Detallar, en un documento, el proceso realizado y que incluya toda la información de las acciones llevadas a cabo durante toda la investigación, las herramientas y *software* utilizados, así como cualquier problema que haya ocurrido durante la investigación.

BUENAS PRÁCTICAS

Normativa

Podemos encontrar diferentes normativas referentes al análisis forense, siendo algunas de ellas:

- **UNE 197010:2015 [\[17\]](#) Criterios generales para la elaboración de informes y dictámenes periciales sobre tecnologías de la información y las comunicaciones (TIC):** esta norma pretende establecer los diferentes requisitos formales que todo informe y dictamen pericial en el ámbito de las TIC debe asegurar. Sin embargo, no hace referencia a los métodos o procesos para llevarlo a cabo.
- **UNE 71505:2013 Tecnologías de la información (TI). Sistema de gestión de evidencias electrónicas (SGEE).** Consta de las siguientes partes:
 - **Parte 1 [\[18\]](#). Vocabulario y principios generales:** recoge la descripción y definición de todos aquellos conceptos de seguridad relativos a la gestión de evidencias informáticas.

4 BUENAS PRÁCTICAS

Normativa

- **Parte 2 [\[19\]](#). Buenas prácticas en la gestión de las evidencias electrónicas:** realiza una identificación de las distintas relaciones existentes entre un sistema de Gestión de Evidencias Electrónicas (SGEE) y un Sistema de gestión de la seguridad de la información (SGSI). Además, especifica los diferentes controles de seguridad que son de aplicación en la gestión de las evidencias informáticas.
- **Parte 3 [\[20\]](#). Formatos y mecanismos técnicos:** describe los formatos de intercambio de las evidencias recogidas, así como los mecanismos técnicos de aplicación para mantener la confiabilidad, integridad y autenticidad de las mismas.

BUENAS PRÁCTICAS

Normativa

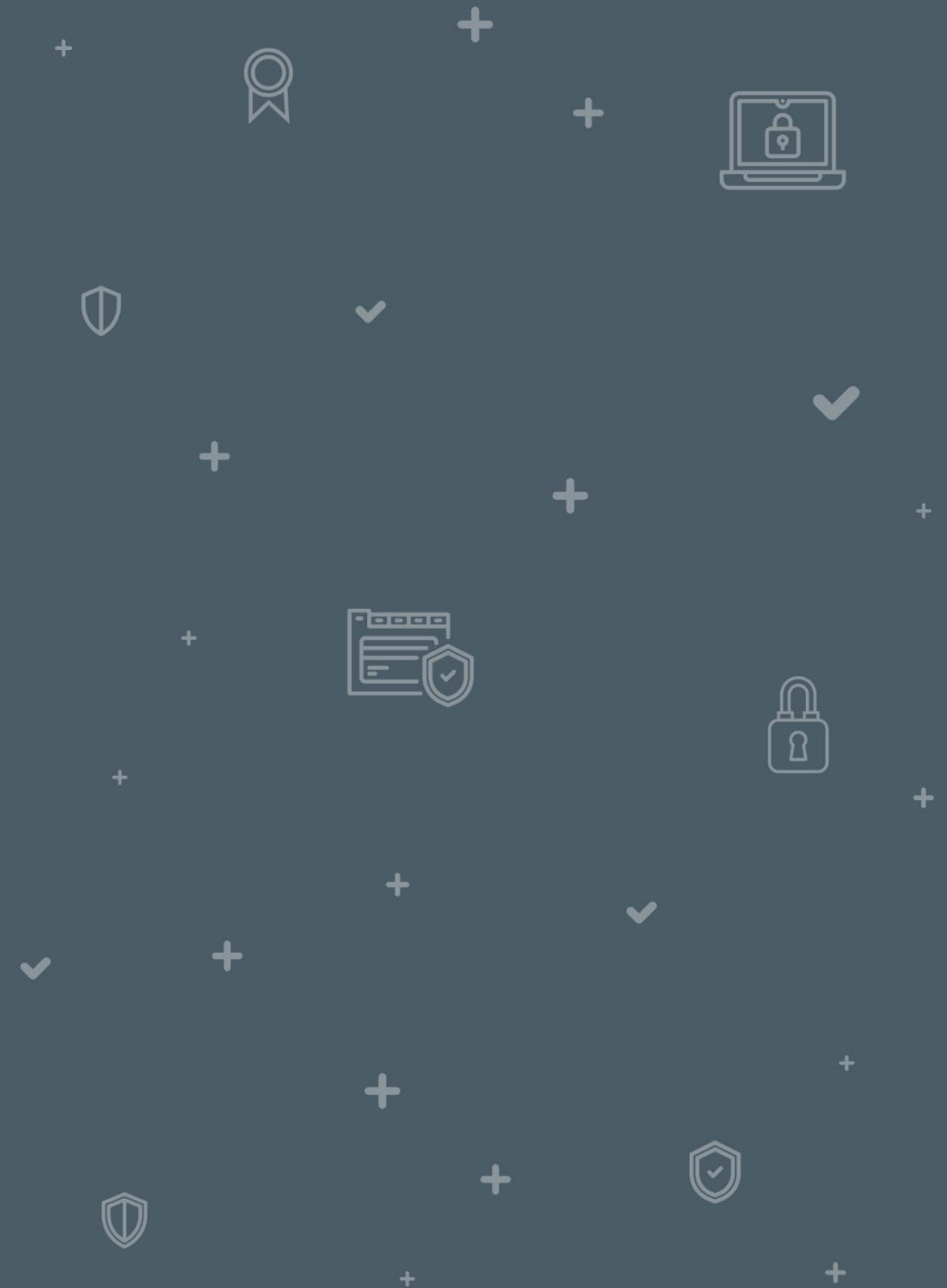
- **UNE 71506:2013 [\[21\]](#) Tecnologías de la información (TI). Metodología para el análisis forense de las evidencias electrónicas:** esta norma recoge el proceso de análisis forense comprendido en el ciclo de gestión de las evidencias electrónicas, siendo las fases de este proceso la preservación de las evidencias, su adquisición, documentación de todo el procedimiento, el análisis de las evidencias y su presentación en un informe pericial.
- **UNE-EN ISO/IEC 27037:2016 [\[22\]](#) Tecnología de la información. Técnicas de seguridad. Directrices para la identificación, recogida, adquisición y preservación de evidencias electrónicas (ISO/IEC 27037:2012):** esta norma recoge las diferentes pautas que se pueden seguir relativas al manejo de las evidencias digitales, comprendiendo procesos diseñados específicamente para asegurar la integridad de las evidencias, así como metodologías que aseguren su admisibilidad en un proceso legal.

4 BUENAS PRÁCTICAS

Normativa

- **UNE-EN ISO/IEC 27042:2016 [\[23\]](#) Tecnología de la información. Técnicas de seguridad. Directrices para el análisis y la interpretación de las evidencias electrónicas (ISO/IEC 27042:2015):** esta norma proporciona una serie de pautas sobre el análisis y la interpretación de las evidencias digitales, comprendiendo diferentes aspectos relativos a su continuidad, validez, reproducibilidad y repetibilidad.

RESUMEN, CONCLUSIONES Y REFERENCIAS



RESUMEN

- Debido a la gran expansión del uso de los **dispositivos móviles** en materia de comunicación, relaciones interpersonales, negocios, hábitos sociales, etc. cada vez es mayor el número de ataques e incidentes que tienen como objetivo estos dispositivos debido al gran volumen de información que almacenan, lo que hace indispensable la capacidad de poder analizarlos en busca de evidencias ante una posible incidencia dentro del ámbito de la investigación forense. La metodología para realizar un análisis forense es similar en todos los dispositivos móviles. El investigador deberá responder a cuestiones, como qué, cuándo, dónde, cómo y por qué ha ocurrido una incidencia, y analizar los diferentes componentes de un dispositivo, como la tarjeta SIM, la memoria interna y la memoria externa.
- **Android** es un sistema operativo de código abierto basado en Linux. Entre los componentes de su arquitectura destaca el Kernel, la capa de abstracción de *hardware* o HAL, el tiempo de ejecución de Android o ART, las bibliotecas C/C++ nativas, el marco de trabajo de la API de Java y la capa de aplicaciones. Por otro lado, el sistema operativo **iOS** se basa en el sistema Unix y cuenta con cuatro capas principales en su arquitectura como capa *core* SO, *core services* o capa de servicios principales, media o capa de medios y *cocoa touch*.

RESUMEN

- Existen **diferencias entre los diferentes sistemas operativos** de los dispositivos móviles que se encuentran en el mercado. Los móviles que poseen UICC se caracterizan porque no poseen una tarjeta SIM extraíble, sino una tarjeta denominada UICC. Se trata de una tarjeta integrada que hace la función de la tarjeta SIM. Por otro lado, los dispositivos iOS cuentan con chips criptográficos denominados *data protection*. Los ficheros que poseen estos chips están protegidos con una clave de alto nivel, que es almacenada como una etiqueta del fichero y las contraseñas también son encriptadas siguiendo el mismo proceso. Por último, los dispositivos Android pueden ser encontrados dentro de tablas de SQLite que están guardadas en archivos separados por cada una de las aplicaciones instaladas.

RESUMEN

- Para poder llevar a cabo un análisis forense en un dispositivo móvil es importante conocer cuáles son las principales vulnerabilidades asociadas a los mismos. Una de las fuentes más fiables relacionada con vulnerabilidades en dichos dispositivos es la plataforma **OWASP**, que define un top 10 de vulnerabilidades: uso inadecuado de plataforma, almacenamiento inseguro de datos, comunicaciones no seguras, autenticación no segura, criptografía insuficiente, autorización insegura, calidad del código de cliente, manipulación de código, ingeniería inversa y funcionalidades no deseadas.
- Con la irrupción de los dispositivos móviles en el mercado, el número de ataques y sus variantes han ido aumentando progresivamente. De esta forma, hemos llegado a un escenario donde existen multitud de ataques con diferentes propósitos. Los **ataques más comunes** a los que se puede enfrentar un dispositivo móvil pueden ser *smishing*, *overlay*, ataques de tipo WEP, ataques de tipo WPA, *bluejacking*, *bluesnarfing*, *bluesmacking*, *replay attack*, RF *jamming*, *clickjacking*, *spyware*, tiendas de aplicaciones no oficiales y el empaquetado de aplicaciones.

RESUMEN

- Para poder enfrentarse a estas vulnerabilidades y ataques, una organización debe concienciar a sus usuarios para mitigar posibles incidencias, asegurando que los dispositivos entregados a los empleados cuenten con medidas de seguridad, definir un protocolo que explique qué aplicaciones se pueden instalar y a qué redes se pueden conectar. Un analista forense de dispositivos móviles también deberá contar con las **políticas de seguridad de la organización**, es decir, un documento que detalle cuáles deberán ser las buenas prácticas que se habrán de tomar para concluir satisfactoriamente un análisis forense de estos dispositivos.

CONCLUSIONES

- Los **dispositivos móviles** son cada vez más relevantes en el día a día y, por ello, se vuelve esencial realizar un análisis forense de manera adecuada de los mismos, dado que estos pueden proporcionar información que no se podría obtener de otra manera.
- Un dispositivo móvil cuenta con los siguientes **componentes físicos** que puede aportar información relevante para la investigación, como la antena, los filtros de radiofrecuencia, los convertidores de señal analógica a digital y viceversa, el procesador de señales de voz, el procesador, la memoria RAM, la memoria ROM, la pantalla, los módulos de cámara, el micrófono, el altavoz y los módulos de conectividad wifi, GPS, memoria externa USB y *bluetooth*.

CONCLUSIONES

- Existen numerosas diferencias entre **dispositivos móviles Android y iOS**, tanto en su arquitectura como en la forma en la que gestionan la seguridad de sus usuarios. Las principales características del sistema operativo Android es que se trata de un sistema creado por el consorcio *Open Handset Alliance*, por lo que su código fuente es *open source* y, además, está basado en arquitectura de Linux. Por otro lado, los dispositivos iOS fueron creados por Apple de manera exclusiva, su arquitectura está basada en Unix y poseen chips criptográficos para la protección de los datos almacenados en ellos.
- Existe una gran variedad de **vulnerabilidades** inherentes a la utilización de dispositivos móviles, como las vulnerabilidades en las aplicaciones, en el sistema operativo, en la Red y en las páginas web y en el contenido de las mismas.
- Algunas de las **técnicas** más utilizadas para que un atacante consiga acceder a la información almacenada en un dispositivo móvil son la ingeniería social, a través de vulnerabilidades en las aplicaciones, la autenticación no segura, los dispositivos IoT, ataques *spyware*, comunicaciones no seguras y sistemas operativos desfasados.

CONCLUSIONES

- El análisis de **artefactos** son una parte esencial del proceso de investigación forense, ya que proporcionan información acerca de contactos y llamadas, mensajes SMS, archivos multimedia, la lista de aplicaciones instaladas, el historial de aplicaciones, cuentas de usuario, conexiones de red y redes wifi.
- El investigador forense deberá asegurarse que cuenta con el equipo adecuado para poder **preservar las evidencias** de manera correcta durante el transcurso de la investigación. Algunos de los métodos de preservación de evidencias son la bolsa de Faraday, las latas de metal contra incendios, el papel de aluminio, la bolsa blindada antiradiofrecuencia y la utilización de inhibidores locales.
- La forma de realizar un análisis forense en dispositivos móviles es muy similar a la de realizar un análisis forense convencional, ya que se desarrolla en las siguientes **fases**: evaluación de la situación, preparación del análisis, recolección y adquisición de evidencias, ya sea del dispositivo o de las aplicaciones y documentación a lo largo de todo el proceso.

CONCLUSIONES

- El **análisis de las aplicaciones** de los dispositivos móviles es también un aspecto muy importante del análisis forense de dispositivos móviles, y existen diferentes aplicaciones específicas para ello, una de las más versátiles para cualquier entorno es MobSF.
- A la hora de **recolectar una evidencia** se deberán tener en cuenta algunos principios para las evidencias volátiles, ya que se pueden perder si se produce algún cambio en el dispositivo que se va a analizar, y para las evidencias no volátiles, que no se perderían si se produjese algún cambio en el dispositivo.
- Existen diferentes métodos para **obtener información** de un dispositivo móvil, ya sea a través de métodos no invasivos, en los que la integridad interna del dispositivo no se ve comprometida, o métodos invasivos, en los que la integridad del dispositivo sí se ve alterada para conseguir obtener información. Dentro de los métodos no invasivos destacan las técnicas de extracción manual, lógica, física, mediante los archivos del sistema y el método de triangulación. Por otro lado, dentro de los métodos invasivos encontramos el método JTAG, *Chip Off* y *Micro Read*.

CONCLUSIONES

- **Otros métodos** que se podrán utilizar para extraer información son *jailbreaking*, *rooting*, *data carving*, memoria externa USB y *Android Debug Bridge*.
- Existen muchas **herramientas para el análisis forense** de dispositivos móviles, como Universal Forensic Extraction Device (UFED), Oxygen Forensic Detective, Autopsy, Caine, FTK Imager y Volatility.
- La **tarjeta SIM**, al igual que la memoria del dispositivo móvil, puede proporcionar información indispensable para una investigación. Asimismo, existen diversas herramientas para poder extraer la información de una tarjeta SIM, como MOBILedit! y SIMCon.

REFERENCIAS

- Cuantos tipos de tarjetas SIM existen y cómo saber cuál necesita mi móvil
<https://www.xatakamovil.com/tutoriales/cuantos-tipos-tarjetas-sim-existen-como-saber-cual-necesita-mi-movil>
- ¿Qué es iOS?
<https://www.adslzone.net/reportajes/software/que-es-ios/>
- La arquitectura de Android.
<https://www.develou.com/aprendiendo-la-arquitectura-de-android/>
- Herramientas para realizar análisis forenses a dispositivos móviles
<https://www.incibe.es/incibe-cert/blog/herramientas-para-realizar-analisis-forenses-dispositivos-moviles>

REFERENCIAS COMPLEMENTARIAS

- [1] Android VS iOS: Cuota de Mercado en 2021.
<https://es.statista.com/grafico/29620/sistema-operativo-movil-con-la-mayor-cuota-de-mercado-por-pais/>

- [2] Una vulnerabilidad pone en peligro al 30 % de los teléfonos Android.
<https://www.xatakandroid.com/seguridad/vulnerabilidad-pone-peligro-al-30-telefonos-android>

- [3] *Data Breach Investigations Report*.
<https://www.verizon.com/business/resources/reports/dbir/>

- [4] ¿Qué es el *smishing*?
<https://www.osi.es/es/actualidad/blog/2021/11/17/que-es-el-smishing>

- [5] WEP, WPA, WPA2 y WPA3: diferencias y explicación.
<https://www.kaspersky.es/resource-center/definitions/wep-vs-wpa>

REFERENCIAS COMPLEMENTARIAS

- [6] Los 5 grandes riesgos de la tecnología *bluetooth*.
<https://www.computing.es/seguridad/los-5-grandes-riesgos-de-la-tecnologia-bluetooth/>
- [7] Seguridad en *bluetooth*: fortalezas y debilidades.
https://como funciona.co/el-bluetooth/?utm_content=cmp-true
- [8] El ataque del *Man in the middle* en la empresa, riesgos y formas de evitarlo.
<https://www.incibe.es/protege-tu-empresa/blog/el-ataque-del-man-middle-empresa-riesgos-y-formas-evitarlo>
- [9] Svpeng, el troyano que amenaza incluso los Android actualizados.
<https://computerhoy.com/noticias/software/svpeng-troyano-que-amenaza-incluso-android-actualizados-66573>
- [10] Qué es Pegasus: como se infecta, qué puede hacer y cómo detectarlo.
<https://www.xataka.com/basics/que-pegasus-como-se-infecta-que-puede-hacer-como-detectarlo>
- [11] La aplicación Google Play eliminó el troyano bancario Vultur en teléfonos Android.
<https://www.zdnet.com/article/google-play-app-dropped-vultur-banking-trojan-on-android-handsets/>

REFERENCIAS COMPLEMENTARIAS

[12] Término *jailbreaking*.

<https://www.incibe.es/aprendeciberseguridad/jailbreaking-rooting>

[13] Cifras definidas por ITU-T.

<https://www.itu.int/pub/T-SP-E.212B-2011/es>

[14] Listado del top 10 riesgos móviles OWASP.

<https://owasp.org/www-project-mobile-top-10/>

[15] Algoritmos criptográficos robustos del National Institute of Standards and Technology (NIST).

<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-175Br1.pdf>

[16] MobSF.

<https://github.com/MobSF/Mobile-Security-Framework-MobSF>

REFERENCIAS COMPLEMENTARIAS

[17] UNE 197010:2015

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0055393>

[18] UNE 71505-2:2013. Parte 1.

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0051411>

[19] UNE 71505-2:2013. Parte 2.

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma/?c=N0051412>

[20] UNE 71505-2:2013. Parte 3.

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0051413>

[21] UNE 71506:2013.

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0051414>

REFERENCIAS COMPLEMENTARIAS

[22] UNE-EN ISO/IEC 27037:2016.

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0057481>

[23] UNE-EN ISO/IEC 27042:2016.

<https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0057471>

¡GRACIAS!

